SECURITY STRATEGY / VERSION 1.0 / 2026-10-21 / PUBLIC EDITION · IDENTIFIERS REDACTED

# Security strategy for the alerting system website and its AWS account

The plan to make the national population-guidance system trustworthy during an evacuation: always reachable, giving guidance no one can tamper with, and protecting location and medical data. It is built on CIS Controls v8.1, CIS Benchmarks, ISO/IEC 27001:2022 and the AWS Well-Architected Security Pillar.

| | |
|---|---|
| **500,000**<br>concurrent public users at peak | **1 of 5**<br>Terraform layers applied (account_infra) |
| **4**<br>critical application findings open (F5, C21) | **12**<br>go-live security gates defined |

CIS Controls v8.1 · IG2 → IG3 | CIS AWS Foundations 7.1.0 | CIS EKS 2.0.0 | CIS Ubuntu L1 | CIS PostgreSQL 17 | CIS NGINX | ISO/IEC 27001:2022 + Amd 1 | AWS WA Security Pillar | OWASP ASVS 5.0 L2 | GDPR & ISO/IEC 27701:2025

# Contents


01 **Executive summary**

Ten moves that matter most

02 **Scope and system context**

Trust zones and data flows

Assets and data classification

Shared responsibility

03 **Framework baseline**

Version gaps you need to manage

04 **Threat model**

STRIDE view of the critical flows

05 **Risk register**

06 **Strategic principles**

07 **Control domains**

7.1 Security foundations and governance

7.2 Identity and access management

7.3 Detection and logging

7.4 Infrastructure protection

7.5 Data protection and privacy

7.6 Application security

7.7 Software supply chain and change

7.8 Incident response and resilience

7.9 People and operations

08 **Design deep dives**

8.1 WAF rules for common attacks and location enforcement

8.2 Security alerting without a staffed SOC

8.3 Separate database users for public and admin

8.4 Separate Kubernetes service accounts for public and admin

8.5 A separate hostname for admin

8.6 Hardened container images

8.7 Admin access without Client VPN: three lower-cost options

8.8 AWS account and organization security

09 **Required changes to the current setup**

10 **Control mapping matrix**

11 **Roadmap and go-live gates**

11.1 Phases

11.2 Go-live security gates

12 **Metrics and reporting**

13 **Decisions needed**

14 **References**

# The platform is well designed, but the application is not yet safe to expose

The AWS platform design is unusually mature for this stage: GitHub OIDC, SHA-pinned actions, signed images, a private EKS cluster, an Imperva edge and an admin plane behind a VPN with MFA. The application inside it is not ready. It has no working authentication or authorization, and its device endpoints are open to the internet. This strategy closes that gap first, then removes the structural risks that sit in the current decisions.

## Ten moves that matter most

01 **Close the public device read surface now, at the platform.** Change the public HTTPRoutes and Imperva rules so only exact public paths and methods (position post, geo lookups) pass. This needs no change to `app/`. See CH-01.

02 **Make admin login and authorization (F5, C21) a hard go-live gate.** Use OIDC against the chosen identity provider, with per-authority RBAC, and remove the seed `admin/admin` account and `NoOpPasswordEncoder`. See SC-05.

03 **Decide the identity provider (B3a).** The recommendation is client Entra ID with phishing-resistant MFA, federated to Client VPN, IAM Identity Center, Argo CD and the console. See B3a.

04 **Strip debug and outdated parts from images.** Remove JDWP on 8787, run as non-root, replace `openjdk:17.0.1` and turn off Swagger in prd. See CH-06.

05 **Move logs to immutable storage with tiered retention, replacing 30-days-and-delete (D35).** Keep security logs at least 1 year, in an Object Lock archive. See CH-03.

06 **Limit how long location data is kept (D34) and drop device emails (C15).** Permanent retention of personal location data is the largest legal and breach exposure. See CH-04.

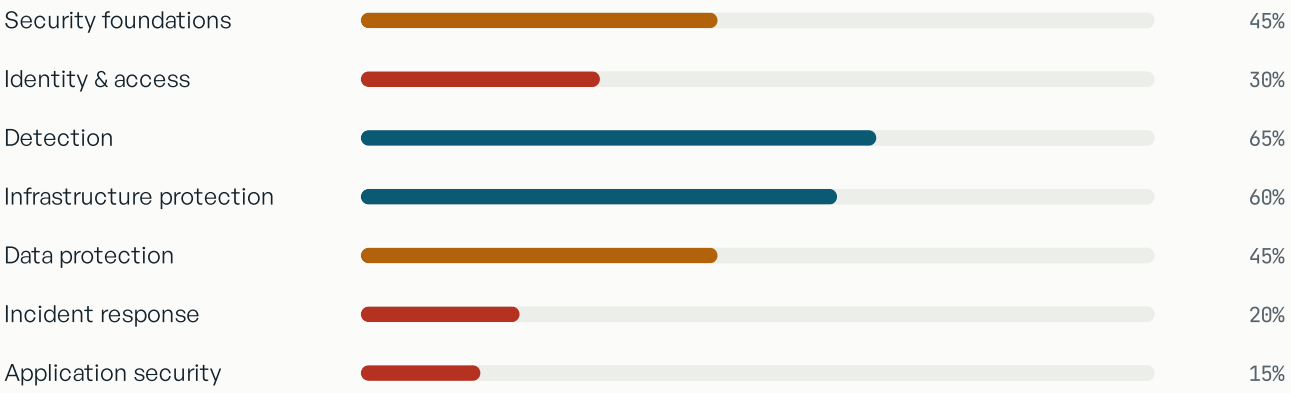
07 **Split prd into its own account, inside AWS Organizations (B25).** Add log-archive and security-tooling accounts and SCP guardrails. See CH-02.

08 **Switch WAF to BLOCK and Kyverno to Enforce with evidence, before go-live** (9.1.7, 9.1.5). Make Imperva origin mTLS mandatory. See SC-11.

09 **De-privilege the database user (D47).** Split owner/migration and runtime roles, and replace `ddl-auto: update` with versioned migrations. See CH-05.

10 **Commission an independent penetration test (B11)** after the Phase 12 fixes and before go-live. Retest, then repeat at least yearly. See B11.

### POSTURE BY WELL-ARCHITECTED AREA (TODAY)




This is a judgment score, not a measurement. It weighs each area's live controls against its design. Designed but unapplied controls count for half. Re-score at each phase gate.

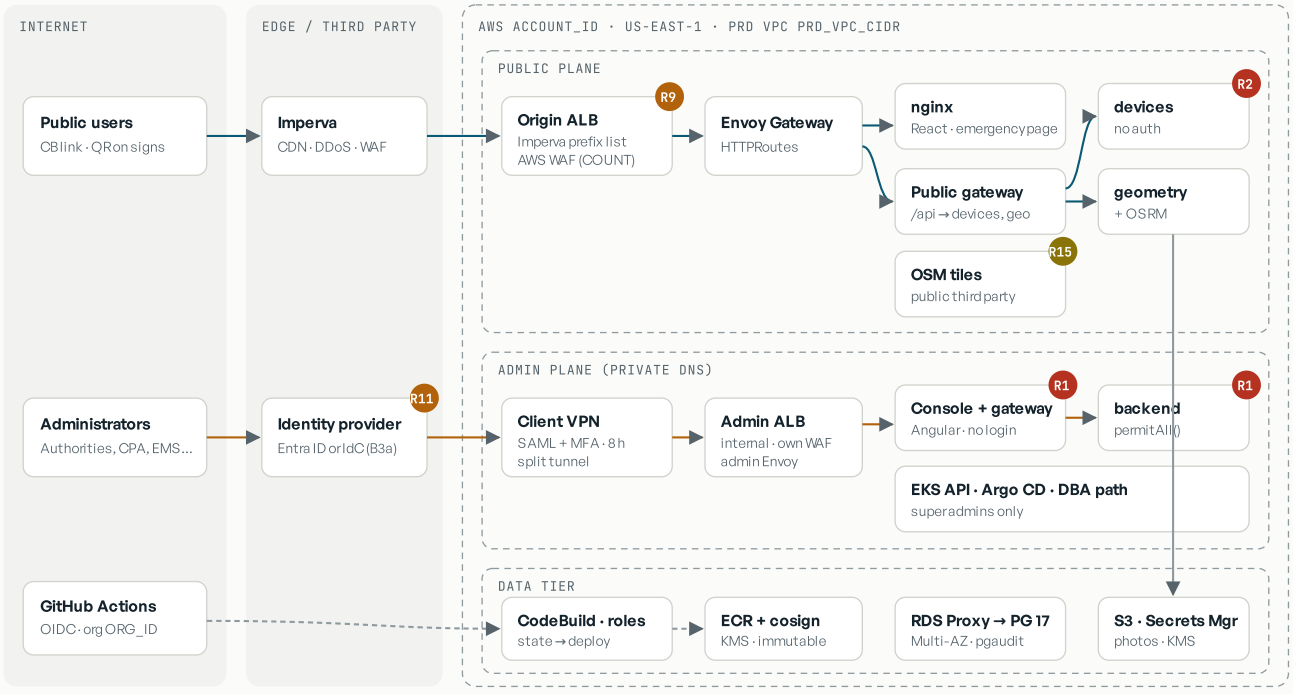
**Bottom line**

Go-live must wait for 12 gates (section 11.2). Seven can be done by the platform team alone. Five depend on the application team or the client.

# What we are protecting, and from whom it is reachable

This strategy covers both faces of the system (the public navigation site and the admin console), the AWS account ACCOUNT_ID in us-east-1 with its `dev` and `prd` environments, the delivery chain (GitHub, CodeBuild, ECR, Argo CD) and the third parties in the path (Imperva, the identity provider).

## Trust zones and data flows




Blue lines show public traffic, amber shows admin traffic, dashed shows delivery. Red markers show where the top risks sit (section 05). The dev VPC (DEV_VPC_CIDR) has the same shape in the same account today.

## Assets and data classification

| ASSET | CLASS | WHY IT MATTERS | TODAY |
|---|---|---|---|
| **Guidance content**<br>assembly areas, routes, instructions, emergency page | Safety-critical integrity | If an attacker changes it, people are sent the wrong way during an evacuation. This is the top impact in the whole system. | Console has no login (F5) |

| ASSET | CLASS | WHY IT MATTERS | TODAY |
|---|---|---|---|
| **Device location samples** | Restricted · personal | Continuous tracks of up to 500,000 people are personal data under privacy law (GDPR and equivalent laws). They show where people live, work and shelter. | Kept permanently (D34) |
| **Medical-need flag and counts** | Restricted · sensitive | Health-related. Must stay as counts per area and never be tied to a device. | Counts per area |
| **Device email** ( `ds_account` ) | Restricted · personal | An identifier that links location tracks to a person. It goes against the stated policy (C15). | Stored; can be looked up from the internet |
| **Occupancy and movement map** | Confidential · operational | Shows where crowds are during an emergency. Its integrity drives decisions by Police, Fire and EMS. | No rate limiting, open check-in |
| **Admin accounts and credentials** | Secret | Whoever holds them controls the guidance. | Plain text, seed `admin/admin` |
| **Platform credentials and keys** KMS, cosign, Secrets Manager, deployment roles | Secret | Control of the supply chain and the data. | Designed well |
| **Authority polygons, photos, logs** | Internal | Logs are also evidence and can contain IP addresses and locations. | Logs 30 days (D35) |

## Shared responsibility

`Platform operator`

### AWS account, network, EKS, data services, CI/CD, detection, NOC

Owns the platform controls in this strategy. Never edits `app/`, but can limit what reaches it through routes, WAF and policy.

`Application team`

### Code in `app/`, its authentication, authorization and APIs

Owns Phase 12 fixes (F5 = 12.1.5). Each fix starts only after the developer approves in writing.

Client & partners

**Steering Committee, CPA, Imperva, IdP owner, AWS**

The Steering Committee owns risk acceptance and residency (B6). Civil Protection Authority (CPA) owns the Cell Broadcast. Imperva owns the edge, and AWS owns security of the cloud.

# How the four frameworks fit together

Each framework does a different job. ISO 27001 is the management system that owns risk and evidence. The CIS Controls set the order of work. The CIS Benchmarks define the exact configuration. The Well-Architected Security Pillar provides the AWS-native design patterns. Every strategic control in section 10 maps to all four.

Management system

### ISO/IEC 27001:2022 (+ Amd 1:2024)

Clauses 4 to 10 define the ISMS: scope, risk assessment and treatment, a Statement of Applicability, internal audit and management review. Annex A has 93 controls in four themes: organizational (37), people (8), physical (14) and technological (34) (Modulos summary of Annex A). Amendment 1 (2024) adds climate-change considerations to the context clauses (ISO). Physical controls A.7 are mostly inherited from AWS and Imperva, and are covered through supplier evidence.

Prioritization

### CIS Critical Security Controls v8.1

18 controls, from asset inventory to penetration testing (CIS). They are grouped into Implementation Groups IG1 to IG3. IG3 is meant for organizations handling sensitive data or critical infrastructure (Cisco CIS v8.1 brief). **Target:** all IG2 safeguards at go-live, then the IG3 safeguards that apply to this system (application-layer filtering, RBAC, code-level checks, application pen testing) within 12 months.

Configuration

### CIS Benchmarks

Current versions: AWS Foundations 7.1.0 (CIS AWS), EKS 2.0.0, which covers Kubernetes 1.34 and 1.35 (CIS June 2026 update), PostgreSQL 17 1.1.0 (CIS PostgreSQL), and NGINX 3.1.0 (CIS NGINX). Add the CIS Ubuntu benchmark (nodes, already L1) and the CIS Docker benchmark (images).

AWS design

### Well-Architected Security Pillar

Seven best-practice areas: security foundations, identity and access management, detection, infrastructure protection, data protection, incident response and application security (AWS Well-Architected). Its design principles include a strong identity foundation, traceability, security at all layers and keeping people away from data (Security Pillar). Section 07 is organized by these seven areas.

## Version gaps you need to manage

**Security Hub automates CIS AWS Foundations only up to v5.0.0**

Security Hub CSPM supports CIS AWS Foundations v5.0.0, 3.0.0, 1.4.0 and 1.2.0, and does not cover every requirement automatically (AWS Security Hub documentation). CIS has since published v7.0.0 and v7.1.0 (CIS April 2026 update). **Strategy:** enable the v5.0.0 standard in Security Hub as the automated baseline. Cover the manual and newer v7.1.0 items with AWS Config custom rules or a quarterly CIS-CAT/Prowler run, and record the results as ISMS evidence.

**EKS 1.36 is newer than the CIS EKS benchmark**

CIS EKS 2.0.0 targets Kubernetes 1.34 and 1.35. Apply it to the 1.36 cluster, record any differences as justified deviations in the Statement of Applicability, and re-baseline when CIS publishes a release that covers 1.36.

**Privacy law is a binding overlay, not optional**

Use the EU GDPR as the global privacy baseline. Most modern privacy laws follow its model. Article 5 requires data minimisation, storage limitation, and integrity and confidentiality of personal data (GDPR Article 5). Under Article 35, a Data Protection Impact Assessment is mandatory for large-scale systematic monitoring, and supervisory authorities list tracking people's location as a trigger (EDPB-published DPIA guidance). Continuous location samples from up to 500,000 devices clearly meet that bar. Run privacy management with ISO/IEC 27701:2025, which is now a stand-alone privacy information management system standard (ISO/IEC 27701:2025). Map the local law of each jurisdiction you operate in onto this baseline, and appoint a DPO.

04 · THREAT MODEL

# Who attacks an emergency system, and when

The attack that matters most comes during a real event or drill, when the site's value and public attention are at their peak. Plan for availability and integrity attacks on the day, and for quiet data theft in between.

TA-1 · State-sponsored

### Disruption or disinformation during a real event

DDoS timed to an alert, tampering with guidance content, a fake guidance site, and pre-positioned access through the supply chain or admin accounts. Targets integrity and availability.

TA-2 · Hacktivists

### Defacement and volumetric DDoS

Opportunistic. Uses public findings like Swagger UI, open device endpoints and default credentials. Will publish any data leak.

TA-3 · Data harvesters

### Bulk extraction of location and contact data

Enumerates `GET /device?all=true` and email lookups. Re-identification and resale. Highest legal impact under GDPR-style privacy law.

TA-4 · Insider or compromised partner

### Misuse of legitimate access

Wide authority user base (Police, Fire, EMS, local authorities, CPA). Shared or leftover accounts, and social engineering of the NOC to scale capacity down.

TA-5 · Physical / local

### QR sticker replacement on signs

A cheap way to send people to a lookalike site. It bypasses every cloud control, so it needs physical and domain-trust countermeasures.

TA-6 · Abuse of public flows

### Fake check-ins and location floods

Bots post fake arrivals or medical flags to distort occupancy, which misleads first responders. There is no rate limiting today (C14).

## STRIDE view of the critical flows

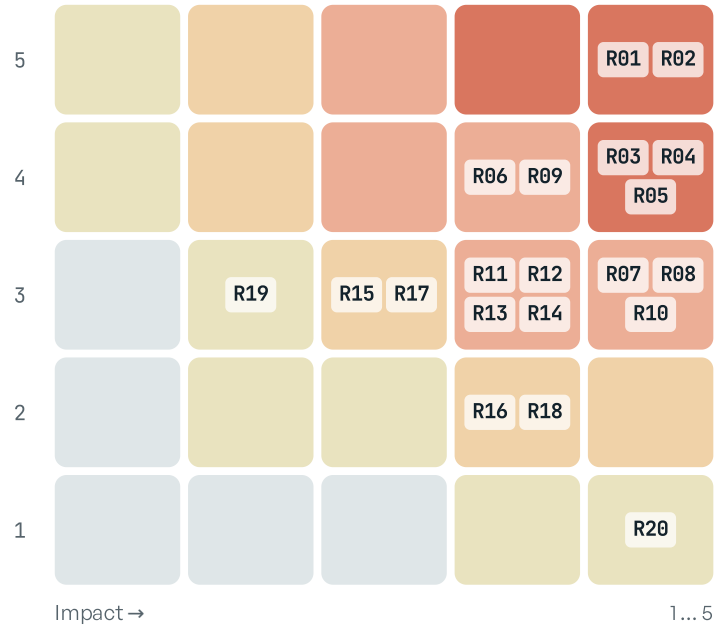
| FLOW | MAIN THREATS | PRIMARY CONTROLS |
|---|---|---|
| Public user → Imperva → origin → devices/geo | DoS, Tampering (fake check-ins), Information disclosure (device enumeration) | SC-11, SC-12, SC-13, SC-26, SC-33 |
| Administrator → VPN → console → backend | Spoofing (no app login), Elevation (no RBAC), Repudiation (no per-user audit) | SC-04, SC-05, SC-08 |
| Service → service (plain HTTP) | Spoofing, Tampering inside the cluster after one pod is compromised | SC-14, SC-17 |

| FLOW | MAIN THREATS | PRIMARY CONTROLS |
| --- | --- | --- |
| GitHub → OIDC → AWS roles → ECR → Argo CD | Tampering (malicious image), Elevation (role trust abuse) | SC-06, SC-24, SC-15 |
| App → RDS Proxy → PostgreSQL | Elevation (superuser app role), Information disclosure | SC-07, SC-18, SC-19 |
| Citizen → sign → QR → domain | Spoofing (lookalike site) | SC-31 |

05 · RISK REGISTER

# Twenty risks, ranked by likelihood and impact

This is the ISO 27001 clause 6.1.2 risk assessment. Likelihood and impact use a 1 to 5 scale, and impact puts life-safety first. Every risk links to the controls and changes that treat it. Click a code in the heat map to jump to that row.




**Reading the map.** Rows show likelihood (5 at the top) and columns show impact. Risks rated Critical (score 20 or more) must be closed or mitigated before go-live. High risks (12 to 19) need a dated treatment plan that the Steering Committee owns.

**Risk appetite (proposed for client approval).** No tolerance for risks to the integrity of guidance or bulk exposure of personal data. Low tolerance for availability risk during an event. Moderate tolerance for confidentiality risk on operational data.

| ID | RISK | L | I | RATING | SOURCE | TREATED BY |
|---|---|---|---|---|---|---|
| R01 | **Admin console and API without authentication**<br>`permitAll()`, plain-text passwords, seed `admin/admin`, no RBAC. Anyone on the VPN can change guidance, and anyone who reaches the gateway can too. | 5 | 5 | Critical | F5, C21 | SC-05 SC-04 CH-01 |
| R02 | **Device data can be read from the internet**<br>Through `GET /device?all=true`, lookup by email, count and check-in. Bulk exposure of personal location data. | 5 | 5 | Critical | F5, C21 | SC-13 CH-01 SC-18 |
| R03 | **JDWP debug agent on 8787 as root, on a 2021 JDK base**<br>JDWP gives remote code execution to anything that can reach the port. Old base image has known CVEs. | 4 | 5 | Critical | C20 | SC-23 CH-06 |

| ID | RISK | L | I | RATING | SOURCE | TREATED BY |
|---|---|---|---|---|---|---|
| R04 | **Guidance spoofing: lookalike domain or swapped QR codes**<br>Citizens are sent to an attacker's page during an evacuation. | 4 | 5 | Critical | Threat model | SC-31 SC-27 |
| R05 | **Outage under DDoS or surge during a real event**<br>Imperva is a single edge, scaling is manual (NOC), and there is a hard cap of four m7g.8xlarge nodes. | 4 | 5 | Critical | Brief, B22 | SC-11 SC-33 SC-26 |
| R06 | **Permanent retention of location samples, plus device emails**<br>Goes against data minimization. A breach would expose the full history. Legal exposure under GDPR storage limitation. | 4 | 4 | High | D34, C15 | CH-04 SC-18 |
| R07 | **Fake check-ins and medical flags distort occupancy**<br>No rate limiting and no device binding. Responders act on false data. | 3 | 5 | High | C14 | SC-26 SC-11 |
| R08 | **dev and prd share one account**<br>A dev compromise or a mistake can reach prd. Permission boundaries and tags are weaker isolation than separate accounts. | 3 | 5 | High | D44, B25 | CH-02 SC-02 |
| R09 | **Preventive controls in observe-only mode**<br>AWS WAF is in COUNT, Kyverno is in Audit and origin mTLS is optional. Attacks are logged, not stopped. | 4 | 4 | High | 9.1.7, 9.1.5, B22 | SC-12 SC-15 SC-11 |
| R10 | **Application database user is `rds_superuser` and owner**<br>Any SQL injection or app compromise has full control of the database. | 3 | 5 | High | D47 | CH-05 SC-07 |
| R11 | **No identity provider and no admin inventory yet**<br>No joiner-mover-leaver process for many partner organizations. | 3 | 4 | High | B3a, B3b | SC-04 B3a |
| R12 | **Lateral movement inside the cluster**<br>Plain HTTP and no authentication between services. NetworkPolicies are the only barrier (C9). | 3 | 4 | High | C9 | SC-17 SC-14 |
| R13 | **Not enough evidence for forensics**<br>All logs kept 30 days with no archive. Investigations and legal requests usually come later than that. | 3 | 4 | High | D35 | CH-03 SC-08 |
| R14 | **NOC tricked into scaling down**<br>Manual scaling with no caller verification (B12). | 3 | 4 | High | B12 | SC-30 B12 |
| R15 | **Third-party map tiles**<br>Public OSM tiles send user locations to a third party and can be throttled during a surge. | 3 | 3 | Medium | C13 | SC-34 |
| R16 | **Supply-chain compromise**<br>GitHub org takeover, a poisoned dependency or base image. Mitigated by OIDC pinning, SHA-pinned actions and cosign, but signature enforcement is still in Audit. | 2 | 4 | Medium | Brief | SC-24 SC-15 |

| ID | RISK | L | I | RATING | SOURCE | TREATED BY |
|---|---|---|---|---|---|---|
| R17 | **Uncontrolled schema changes**<br>`ddl-auto: update` with no migrations. A drifting schema can cause data loss. | 3 | 3 | Medium | C23 | SC-35 CH-05 |
| R18 | **Residency drift**<br>Imperva logs, PoPs or IdP data stored outside the approved jurisdiction before B6 is confirmed. | 2 | 4 | Medium | B6, B22 | SC-29 B6 |
| R19 | **Posture blind spots**<br>CIS standard INCOMPLETE, FSBP unscored, default VPC still present. | 3 | 2 | Medium | Live state | SC-10 CH-08 |
| R20 | **Root or break-glass misuse**<br>Account root and the cluster break-glass role are the only unlimited identities. | 1 | 5 | Medium | Baseline | SC-03 |

# Seven rules that decide trade-offs

When two good controls conflict, such as caching against freshness, or strict blocking against reachability during a surge, apply these principles in order.

01 **Life-safety first: integrity, then availability, then confidentiality.** Guidance must be correct before it is fast, and fast before it is private. A cached, signed emergency page is better than a live page that may have been tampered with.

02 **Fail to a known-good degraded mode, never to open.** If the cluster is down or overloaded, the edge serves the static emergency page. If authentication fails, admin writes are denied.

03 **Public plane is read-mostly and explicitly allow-listed.** Only named paths and methods are routed. Everything else returns 404 at the edge.

04 **Every human is named, federated and phishing-resistant.** No shared accounts, no local passwords in the app, and MFA everywhere a person authenticates.

05 **Collect less, keep less.** Store the minimum needed for the evacuation purpose, for a set time, then aggregate or delete. Retention is set per data class, not as one rule for everything.

06 **Platform compensates, app remediates.** The platform team contains application weaknesses with routing, WAF, policy and network controls, but never treats that as permanent. Each compensating control has an expiry tied to a Phase 12 task.

07 **Everything as code, everything evidenced.** Controls live in Terraform, Argo CD and Kyverno. Their state is measured continuously in Security Hub and Config, and the results feed the ISO 27001 evidence pack.

# The strategy by Well-Architected area

For each area: where it stands today, the target state, and the specific work. The tags show the main CIS Controls (CIS n), ISO Annex A controls (A.x.y) and CIS Benchmarks that apply.

## 7.1 Security foundations and governance

`ISO Cl. 4–10` `A.5.1–5.4` `A.5.19–5.23` `CIS 15` `WA SEC01`

**TODAY**

- Strong decision log (D-, B-, C- items) and ADRs
- One account, dev and prd separated by tags and boundaries
- No ISMS scope, policy set or Statement of Applicability
- Supplier security (Imperva, IdP, app team) not formalized

**TARGET**

- ISMS scoped to "the alerting system service and its AWS platform", with the Steering Committee as owner
- AWS Organizations: management, security tooling, log archive, prd and dev accounts
- SoA covering all 93 Annex A controls, with justification for each exclusion
- Supplier register with security clauses, DPAs and residency commitments

- Work items

- Write a one-page information security policy plus topic policies: access control, cryptography, logging, retention, supplier, secure development, incident response, acceptable use (A.5.1, A.5.37).
- Set up a RACI covering the platform team, the application team, the Steering Committee, CPA and Imperva (A.5.2, A.5.3 segregation of duties). The prd approver must not be the author.
- Adopt the risk method in section 05. Review it quarterly and after every drill (Cl. 6.1, 8.2).
- Create a separate prd account (CH-02) with SCPs that deny leaving the org, deny disabling CloudTrail, Config, GuardDuty or Security Hub, deny Regions other than us-east-1 (residency), and deny creating IAM users or access keys. The full guardrail set, account baseline and rollout order are in 8.8.
- Run internal audit and management review twice a year, aiming for ISO 27001 certification readiness within 12 months of go-live.

## 7.2 Identity and access management

`CIS 5, 6` `A.5.15–5.18` `A.8.2, A.8.5` `CIS AWS §IAM` `WA SEC02–03`

TODAY

- GitHub OIDC with pinned `sub`, ExternalId, permission boundaries
- EKS access entries and Pod Identity, break-glass as the only cluster-admin
- Client VPN with SAML and MFA, but the IdP is undecided (B3a)
- Application: no working login and no authorization model (F5)

TARGET

- One workforce IdP for all human access, with phishing-resistant MFA (FIDO2 or passkeys) for super admins
- IAM Identity Center for AWS console and CLI. No IAM users.
- App uses OIDC with role and scope claims: authority, area and screen
- Quarterly access reviews and automatic deprovisioning

- Work items

- **Humans (AWS):** federate Identity Center to the chosen IdP. Use permission sets for Viewer, Operator, Deployer (break-glass) and Auditor. Enforce MFA. Allow console sessions of 8 hours at most, and 1 hour for admin permission sets.
- **Humans (app):** the admin gateway validates OIDC tokens. The backend enforces `@PreAuthorize` on every endpoint. A data model links users to groups, screens and locations, matching the PRD's two user types (CIS 6.8 RBAC, A.5.15).
- **Root:** hardware MFA, no access keys, root-usage alarm, contact details current. Once the Organization exists, use centralized root access management (CIS AWS Foundations IAM section).
- **Break-glass:** two named sealed identities. Each use triggers a page to the security owner and a mandatory post-use review (A.8.2).
- **Workloads:** keep Pod Identity, with one role per service account, scoped to the exact secret ARN and KMS key. Turn on IAM Access Analyzer unused-access findings.
- **CI:** keep OIDC with immutable `sub`. Add `job_workflow_ref` conditions so only named workflows can assume the deploy roles.

## 7.3 Detection and logging

`CIS 8, 13` `A.8.15, A.8.16` `A.5.28` `CIS AWS §Logging/Monitoring` `WA SEC04`

TODAY (LIVE)

- CloudTrail multi-Region with validation, Config with a conformance pack
- GuardDuty with S3, EKS audit, malware and runtime monitoring; Security Hub; Access Analyzer; Inspector
- CIS standard INCOMPLETE, FSBP unscored
- All logs 30 days, no archive (D35)

TARGET

- Log-archive account with S3 Object Lock (compliance mode), KMS, us-east-1
- Tiered retention: security logs 1 year hot plus 6 years cold, operational logs 30 to 90 days
- Security Hub FSBP and CIS v5.0.0 at 95% or more passing, with tracked exceptions
- 24/7 alert routing with runbooks for the 15 top detections

- Work items

- Fix the CIS standard: disable it and re-enable CIS v5.0.0 now that Config is recording, then confirm READY. AWS re:Post notes that Security Hub retries INCOMPLETE standards about every 12 hours (AWS re:Post).
- Ship ALB, Envoy, Imperva, VPC Flow, EKS audit, pgaudit and Client VPN connection logs to the archive. Keep at least 90 days hot to meet CIS 8.10.
- Add app-level audit events: who changed which guidance object, from where and when. This removes the repudiation risk.
- Detection use cases: guidance changed outside a change window, admin login from a new country, a spike in reads of the device list, high error rates at the Envoy proxy, a GuardDuty runtime finding on any node, a disabled security service, root usage, a break-glass assumption, a cosign verification failure, a WAF block-rate anomaly, a scale-down request outside the procedure.
- Time sync: confirm nodes use the Amazon Time Sync Service and that Imperva log timestamps are UTC (A.8.17).

## 7.4 Infrastructure protection

`CIS 4, 12, 13` `A.8.20–8.22` `A.8.9` `CIS EKS 2.0.0` `CIS Ubuntu L1` `CIS NGINX` `WA SEC05–06`

**TODAY (DESIGNED)**

- Imperva → origin ALB limited to an Imperva prefix list. AWS WAF in COUNT, optional mTLS.
- Private EKS endpoint, CIS L1 Ubuntu nodes, IMDSv2 with hop limit 1, SSM only
- PSA restricted, Kyverno in Audit, default-deny NetworkPolicies
- The whole `/api` prefix is proxied, and the default VPC still exists

**TARGET**

- Imperva with mandatory origin mTLS and a trusted client-IP header. The origin rejects anything else.
- AWS WAF in BLOCK with managed rules, rate rules and route allow-lists
- Kyverno Enforce: non-root, signed images, registry allow-list, no privileged pods
- Egress allow-list. No route to the internet except named destinations.

- Work items

- **Edge:** make origin mTLS mandatory (a client certificate from Imperva, validated by an ALB trust store). Keep the prefix list as a second layer. Use only the Imperva client-IP header for rate limiting and logs, and strip it at the edge if it arrives from outside.
- **Routes:** public Envoy HTTPRoutes match exact paths and methods (CH-01). nginx must not proxy `/api` as a prefix. Block `/swagger-ui`, `/v3/api-docs` and `/actuator` at Imperva and at AWS WAF.
- **EKS:** score against CIS EKS 2.0.0. Enable control-plane logging for audit and authenticator, KMS envelope encryption of Kubernetes Secrets, and pin the Envoy Gateway and Kyverno charts by digest.
- **Nodes:** keep CIS Ubuntu L1. Adopt the L2 items that don't break workloads (auditd rules, kernel module blacklist) and record the rest as deviations.
- **nginx:** apply CIS NGINX items: run as non-root, `server_tokens off`, security headers (CSP, HSTS, X-Content-Type-Options, frame-ancestors), TLS settings handled at Imperva and the ALB.
- **Network:** delete the default VPC in every Region, add VPC endpoints for S3, ECR, STS, Secrets Manager, KMS and logs, and route remaining egress through AWS Network Firewall with an FQDN allow-list.

## 7.5 Data protection and privacy

`CIS 3, 11` `A.5.12, A.5.33, A.5.34` `A.8.10-8.13, A.8.24` `CIS PostgreSQL 17` `WA SEC07-09`

TODAY

- KMS customer keys per env, Secrets Manager, CSI-mounted secrets
- RDS Multi-AZ, deletion protection, pgaudit, IAM tokens for DBAs
- Location kept permanently (D34), email per device (C15)
- App user is `rds_superuser` (D47). No backup vault policy defined.

TARGET

- Classification scheme from 2.2, applied through tags
- Raw location samples kept 30 days after an event closes (proposed), then aggregated to area and time
- Least-privilege DB roles, TLS required to RDS, encrypted backups in a separate account with vault lock
- Encryption in transit everywhere, including between services

- Work items

- **Minimization (CH-04):** replace D34 with a retention rule per class. Remove `ds_account.email`. Use a random device identifier that rotates for each event.
- **Database (CH-05):** roles `alerting_owner` (migrations only, through CI), `alerting_app` (DML on named tables), `alerting_ro` (reporting). Set `rds.force_ssl=1`.
  Apply the CIS PostgreSQL 17 items that apply to RDS: logging parameters, `pgaudit.log` classes, `log_connections`.
- **Backups:** AWS Backup plan with PITR at least 7 days and daily snapshots for 35 days, copied to a backup vault in a separate account in us-east-1 with Vault Lock. Run a restore test every quarter (CIS 11.4, A.8.13).
- **Keys:** separate key policies for administrators and users of keys, yearly rotation, deny `kms:ScheduleKeyDeletion` through SCP except for break-glass.
- **Photos (C17):** uploaded only through the admin plane with presigned PUT URLs, scanned by GuardDuty Malware Protection for S3, served through the edge with no public bucket.
- **Privacy:** run a DPIA, publish a privacy notice on the public site (purpose, retention, rights), and notify or register with the supervisory authority where the local law requires it.

## 7.6 Application security

`CIS 16, 18` `A.8.25–8.29, A.8.32` `OWASP ASVS 5.0 L2` `CIS Docker` `WA SEC11`

**TODAY**

- Strong supply chain: single build, SBOM, provenance, Trivy and Inspector gates, cosign, immutable tags
- No authentication or authorization, open device endpoints, Swagger served
- JDWP on 8787, root user, `openjdk:17.0.1`, tests skipped
- No rate limiting, `ddl-auto: update`

**TARGET**

- OWASP ASVS 5.0 Level 2 as the acceptance standard for Phase 12 (OWASP ASVS)
- Distroless or slim supported JRE base, non-root, no debug agents in any image
- Separate public and admin APIs, built from separate controllers
- SAST, SCA, secret scanning and DAST in the pipeline, with blocking thresholds

- Work items (Phase 12, need written developer approval)

- **12.1.5 / F5:** remove `permitAll()`, HTTP basic and `NoOpPasswordEncoder`. Validate resource-server JWTs from the IdP. Delete the seed in `data.sql`. Remove the `/auth/**` route to the missing service.
- **C21:** split the devices controller into a public part (position post, arrival, medical flag, own device only) and an admin part (list, lookup, count) that is reachable only through the admin gateway.
- **Device binding:** issue a short-lived signed device token on first visit. Each post must carry it. Rate-limit per token and per IP (SC-26).
- **C20:** new Dockerfiles. Multi-stage, supported JRE 17 or 21 base, `USER 10001`, no JDWP, tests run in CI. Swagger turned off in prd by profile.
- **C23:** set `ddl-auto: validate` and use Flyway or Liquibase migrations run as a Kubernetes Job with the owner role.
- **Pipeline:** add CodeQL or Semgrep SAST, dependency review, gitleaks, and an OWASP ZAP baseline scan against dev in workflow 05. Block on High and Critical findings.

## 7.7 Software supply chain and change

`CIS 2, 7, 16` `A.8.4, A.8.8, A.8.30-8.32` `WA SEC11`

This is the strongest area today. The strategy keeps it and closes the enforcement loop. Signature verification moves to Enforce, the GitHub org is hardened and vulnerability handling gets SLAs.

- Work items

- Kyverno `verifyImages` in Enforce for `alias/alerting-prd-cosign` with digest pinning, plus a registry allow-list limited to the prd ECR and the pull-through cache.
- GitHub org: SSO and MFA required, branch protection with signed commits, CODEOWNERS on `infra/` and workflow files, required reviewers for `prd` environments, and no self-approval.
- Vulnerability SLAs (CIS 7): Critical 7 days, High 30 days, Medium 90 days, measured from the first Inspector or Trivy finding. Rebuild nodes monthly (already planned), and rebuild images weekly from the base.
- Keep the console CodeBuild fallback, but run it only from the same signed source and the same role chain, and log every manual use.

## 7.8 Incident response and resilience

CIS 17, 11 | A.5.24-5.30 | A.6.8 | WA SEC10

**TODAY**

- Findings SNS topic and weekly digest
- NOC scales by hand, with no caller verification
- No IR plan, playbooks, or forensics account

**TARGET**

- IR plan with named roles: incident commander, comms (with CPA), legal or DPO
- Eight playbooks, each exercised once a year, and DDoS plus surge drills before each national exercise
- Forensics role and isolated account, pre-approved isolation actions

- Playbooks

1. DDoS or surge during a live event: Imperva escalation, AWS Shield, scale-up order and emergency page fallback.
2. Unauthorized guidance change: freeze writes, restore from the audit trail, notify CPA.
3. Admin account compromise: disable the user at the IdP, revoke sessions, review audit events.
4. Personal data exposure: contain, assess, notify the supervisory authority and affected people as the law requires.
5. Malicious or unsigned image: Kyverno blocks it, Argo CD rolls back, the signing key is rotated.
6. Compromised node or pod: GuardDuty runtime finding, cordon and isolate, EBS snapshot, rebuild.
7. Lookalike site or swapped QR codes: takedown requests, public messaging through CPA, sign sweep.
8. Social engineering of the NOC: verification failed, escalate, keep current capacity.

## 7.9 People and operations

CIS 14 | A.6.1-6.8 | A.5.37

### Role-based training

Administrators at each authority get yearly training on phishing, MFA fatigue and how to report. Platform engineers get secure Terraform and Kubernetes training. The app team gets ASVS-based secure coding.

### NOC procedure

A capacity change needs a ticket ID and a callback to a registered number. Scale-down also needs a second approver (B12).

### Screening & offboarding

Screening for super admins in line with client policy. When a person leaves, IdP deprovisioning is the single off-switch, checked in the quarterly access review.

# Eight design questions, answered in detail

This section covers WAF rules and location enforcement, alerting without a staffed SOC, database users, Kubernetes service accounts, the admin hostname, hardened container images, lower-cost alternatives to Client VPN for admin access, and AWS account and organization security. Each topic opens with a direct answer, then gives the concrete rules, roles or options, and links back to the risks, changes and controls they support.

## 8.1 WAF rules for common attacks and location enforcement

CIS 13.10 | A.8.20, A.8.23 | WA SEC05 | ASVS V4

**Short answer: some protection is on by default, but most of what this system needs is manual**

**Imperva** applies its default account WAF Rules policy to every new site automatically. In that policy, SQL injection, cross-site scripting, illegal resource access and remote file inclusion are all set to Block Request (Imperva policies). Backdoor protection defaults to Auto-Quarantine (Imperva WAF settings). Bad bots are denied and good bots allowed by default (Imperva security settings).

**AWS WAF** has no protection until you add rules. A web ACL with no matching rule just applies its default action, normally Allow (AWS WAF default action). Every managed rule group has to be added and tuned.

**Manual in both layers:** the public path allow-list, rate limits, country rules, and anything specific to this API.

### How the two layers share the work

- **Imperva (edge, primary):** sees the real client IP, absorbs DDoS, filters bots and reputation, and applies the OWASP rules. It is the only layer that can do IP reputation and anonymizer filtering correctly for the public plane.
- **AWS WAF on the origin ALB (second layer):** applies AWS managed rules for Java and PostgreSQL attacks, enforces the exact public route allow-list, and adds per-client rate limits. It also guards against anything that slips past Imperva.
- **AWS WAF on the admin ALB:** applies managed rules plus a short allow-list of admin routes. It reaches only VPN users, so it doesn't need bot or geo rules.

| ID | RULE | LAYER | DEFAULT OR MANUAL | ACTION AND NOTES |
|---|---|---|---|---|
| WAF-01 | **OWASP rules policy**<br>SQLi, XSS, illegal resource access, RFI | Imperva | Default, applied automatically | Block Request. Confirm that no site or rule has been switched to Alert Only, and that the account policy is attached to the public site. |
| WAF-02 | **Backdoor protection** | Imperva | Default | Auto-Quarantine. Keep it. |
| WAF-03 | **Bot access control** | Imperva | Default (bad bots denied, good bots allowed) | Keep it. Don't put a CAPTCHA on public pages, because people must not hit a puzzle during an evacuation. Use a JavaScript challenge only on the position write path, and only while under attack. |
| WAF-04 | **DDoS protection** settings | Imperva | On, but the threshold needs tuning | Set the detection threshold for peak load (500,000 concurrent users), so a real event doesn't look like an attack. Depends on the Imperva tier (B22). |
| WAF-05 | **Public route allow-list**<br>positive security | Imperva ACL + AWS WAF | Manual | Block anything that isn't a listed method and path: site assets, the emergency page, the position POST and the geo routes. Explicitly deny `/api/backend-service/**`, `/api/v1/swagger-ui`, `/actuator/**`, `GET /device?all=true`, lookup by email, and count. This puts CH-01 into practice and contains R02. |

| ID | RULE | LAYER | DEFAULT OR MANUAL | ACTION AND NOTES |
|---|---|---|---|---|
| WAF-06 | **Rate limits per client** | Imperva rules + AWS WAF rate-based | Manual | Use separate limits for the position POST, geo and OSRM routing, and site assets. Set thresholds high, because carrier-grade NAT puts many phones behind one IP. Prefer Challenge over Block on read paths. Imperva rules support rate criteria (Imperva rules). In AWS WAF, aggregate on the forwarded client IP (AWS WAF rate-based rules). Addresses C14, R05 and R07. |
| WAF-07 | **Core rule set** `AWSManagedRulesCommonRuleSet` | AWS WAF | Manual (add it) | Block. It covers a wide range of vulnerabilities from the OWASP Top 10 (AWS baseline rule groups). If the COUNT period shows false positives on the position body, override the size-restriction rules. |
| WAF-08 | **Known bad inputs** `AWSManagedRulesKnownBadInputsRuleSet` | AWS WAF | Manual | Block. It includes Log4j and Java deserialization RCE rules (AWS changelog), which matter for a Spring and Java stack. |
| WAF-09 | **SQL database** `AWSManagedRulesSQLiRuleSet` | AWS WAF | Manual | Block. It covers SQL injection patterns (AWS use-case rule groups), which matters with PostgreSQL behind every service. |
| WAF-10 | **Linux OS** `AWSManagedRulesLinuxRuleSet` | AWS WAF | Manual | Block. Catches local-file-inclusion attempts against Linux paths. |

| ID | RULE | LAYER | DEFAULT OR MANUAL | ACTION AND NOTES |
|---|---|---|---|---|
| WAF-11 | **Admin protection** `AWSManagedRulesAdminProtectionRuleSet` | AWS WAF (public ACL only) | Manual | Block. Admin paths must never be served on the public plane. Leave it off the admin ALB. |
| WAF-12 | **IP reputation and anonymous IP lists** | Imperva, not AWS WAF | Manual choice | The AWS groups use the source IP of the request, which behind a proxy is the proxy's address (AWS IP reputation groups). Behind Imperva they would only see Imperva's own IPs. Use Imperva's reputation features instead. Block anonymizers and hosting providers on the write path only. |
| WAF-13 | **Origin guard** | ALB SG + AWS WAF | Manual | Keep the Imperva-only prefix list. Add mandatory origin mTLS or a secret header that AWS WAF checks, so the origin can't be reached without going through Imperva (CH-07). |
| WAF-14 | **Bot Control, account takeover protection** | AWS WAF | Optional (paid) | Not needed in release one: Imperva handles bots, and admin login is VPN-only. Reconsider if a public account feature is ever added. |

### Location enforcement

Location means three different things here, and each needs a different control.

- **Admins: enforce it at the identity provider, not the WAF.** Admin traffic arrives over the VPN, so the WAF never sees the admin's real location. If the IdP is Entra ID (B3a), use a Conditional Access location policy to block sign-in from outside the service country (Microsoft Entra). Alert on any VPN connection from an unexpected country (AL-17).
- **Public reading: don't geo-block.** With home-routed roaming, the most common setup, a visitor's traffic leaves the internet through their home operator. A tourist in the service area therefore shows up with a foreign IP (ipregistry). A country block would turn away exactly the visitors who most need guidance. Label requests by country instead (rule action Count), and apply stricter rate limits to traffic from outside the service country.

- **Public writes (position samples): enforce it in the application, with WAF help.** An IP address can't tell you where a device is. The real control is server-side: reject any coordinate outside the service-area polygon (PostGIS `ST_Within`), any implausible speed between samples, and any timestamp out of range (R07). At the edge, block anonymizers and hosting providers on this path, and apply the tightest rate limit.
- **Make AWS WAF see the real client.** Geo match and rate-based rules can read the client address from a forwarded IP header instead of the request origin (AWS forwarded IP). Configure them to read Imperva's client IP header (B22). That header can only be trusted because the origin accepts nothing but Imperva (WAF-13).
- **Hard country blocking, if the client wants it anyway:** apply it only to the write path, with Imperva's ACL Block Countries (Imperva policies), and record the accepted impact on roaming visitors.

## 8.2 Security alerting without a staffed SOC

`CIS 8.11, 13.1, 17` `A.5.24-5.26, A.8.16` `WA SEC04, SEC10`

> **Short answer: yes, use an alert-only model with three tiers and no dashboards**
>
> AWS services already do most of the correlation. Since December 2025, Security Hub correlates and enriches signals from GuardDuty, Inspector and Security Hub CSPM to surface critical risks (AWS Security Hub GA). GuardDuty Extended Threat Detection raises a single Critical attack-sequence finding for a likely compromised EKS cluster (GuardDuty attack sequences).
>
> Your job is routing: send the few findings that matter to people, and roll everything else into a weekly digest. A full SIEM can come later, if a client SOC wants the feed.

### Pipeline

1. **Sources:** Security Hub (findings from GuardDuty, Inspector and CSPM), CloudTrail management events, AWS WAF and Imperva events, Client VPN connection logs, pgaudit, Kyverno, synthetic canaries, and app audit events.
2. **Noise control first:** Security Hub automation rules suppress findings or change their severity before EventBridge sees them (Security Hub automations). Use them to tag prd resources as higher severity, and to suppress accepted exceptions that have an expiry date.
3. **Routing:** EventBridge rules and CloudWatch alarms send to one SNS topic per tier, replacing the single findings topic.
4. **Delivery:**
   - P1 goes to an on-call paging tool (phone and SMS).
   - P2 goes to a chat channel through Amazon Q Developer in chat applications, which forwards SNS notifications to Slack or Teams (Amazon Q Developer in chat), plus email.
   - P3 goes into the weekly digest.
5. **Runbook link in every alert:** each alert carries the alert ID and the first three actions to take.

6. **Testing:** monthly, generate GuardDuty sample findings and fire one synthetic event per P1 rule, then confirm that the page arrived and was acknowledged.

| TIER | MEANING | DELIVERY | TARGET RESPONSE |
|---|---|---|---|
| P1 | Likely compromise, or loss of integrity or availability of guidance | Page 24/7 (phone and SMS), plus chat | Acknowledge in 15 minutes, start containment in 1 hour |
| P2 | Serious misconfiguration or suspicious activity, with no sign of compromise yet | Chat plus email, during working hours. During an event or drill, P2 becomes P1. | Triage the same working day |
| P3 | Hygiene and posture | Weekly digest | Review weekly, fix by priority |

| ID | ALERT RULE | SOURCE | TIER | FIRST RESPONSE |
|---|---|---|---|---|
| AL-01 | **Any GuardDuty attack sequence** `AttackSequence:*` | GuardDuty via Security Hub | P1 | Isolate the affected workload or role, preserve evidence, follow the incident playbook |
| AL-02 | **GuardDuty finding of High severity or above** runtime, EKS audit, IAM credential misuse, malware | GuardDuty | P1 | Cordon the node and quarantine the pod. Rotate the credential. |
| AL-03 | **Root user activity** | CloudTrail via EventBridge (CIS CloudWatch.1) | P1 | Confirm with the root custodian. If not expected, treat as compromise. |
| AL-04 | **Break-glass role assumed** | CloudTrail | P1 | Confirm the incident ticket. Start the post-use review. |
| AL-05 | **Security control disabled or weakened** CloudTrail stopped, GuardDuty, Security Hub or Config off, WAF ACL detached or set to Count, Kyverno policy deleted | CloudTrail, Kubernetes audit | P1 | Re-enable the control. Identify who made the change. |
| AL-06 | **KMS key disabled or scheduled for deletion** | CloudTrail | P1 | Cancel the deletion. Review the key policy. |

| ID | ALERT RULE | SOURCE | TIER | FIRST RESPONSE |
|---|---|---|---|---|
| AL-07 | **Guidance content changed outside a change window, or by an unexpected identity** | App audit events (7.3) | P1 | Freeze publishing. Verify with the content owner. Roll back if not approved. See R01. |
| AL-08 | **Public site or emergency page unavailable from outside** | Synthetic canaries in two or more locations | P1 | Fail over to the static emergency page (CH-12). Engage Imperva. |
| AL-09 | **Internet request reached a blocked admin or device-list path at the origin**<br>should be zero | Envoy and ALB logs (metric filter) | P1 | Find the bypass. Block at the edge. Check what was read (R02). |
| AL-10 | **Imperva DDoS mitigation or attack alert** | Imperva notifications | P2 (P1 during an event) | Check site health and the emergency page. Coordinate with Imperva. |
| AL-11 | **WAF block-rate anomaly or rate rule firing**<br>more than 5 times baseline for 15 minutes | AWS WAF metrics, Imperva events | P2 | Check for false positives against real attack traffic. Tune or escalate. |
| AL-12 | **IAM and organization changes**<br>new IAM user or access key, admin policy attached, SCP or permission boundary changed | CloudTrail | P2 (P1 in prd) | Verify against an approved change. Revert if none exists. |
| AL-13 | **New public exposure**<br>SG or NACL open to 0.0.0.0/0, public S3, new internet-facing LB or listener, exposure finding | Security Hub CSPM and exposure findings, CloudTrail | P2 | Close the exposure. Run a change review. |
| AL-14 | **Critical CVE in a running prd image** | Inspector | P2 (P1 if a public exploit exists) | Patch or rebuild within the SLA (8.6) |
| AL-15 | **Admission denied in prd**<br>Kyverno Enforce violation, cosign verification failure | Kyverno events, Kubernetes audit | P2 | Find the source of the image or manifest. A cosign failure in prd means a P1 investigation. |
| AL-16 | **Database anomaly**<br>GuardDuty RDS anomalous login, DDL in prd outside the migration job, login as the owner or superuser role | GuardDuty RDS Protection (GuardDuty RDS), pgaudit | P2 | Identify the session. Rotate the role's credentials if not expected (8.3). |

| ID | ALERT RULE | SOURCE | TIER | FIRST RESPONSE |
|---|---|---|---|---|
| AL-17 | **Admin access anomaly**<br>VPN connection from an unexpected country or at an unusual hour, repeated admin sign-in failures, IdP risk detection | Client VPN connection logs, IdP | P2 | Contact the admin through a known channel. Revoke the session if not confirmed. |
| AL-18 | **Secret read by an unexpected principal**<br>a prd DB secret read by anything other than its own pod role | CloudTrail `GetSecretValue` | P2 | Rotate the secret. Review the role trust. |
| AL-19 | **Console sign-in without MFA** | CloudTrail (CIS CloudWatch.3) (Security Hub CloudWatch controls) | P2 | Disable the identity. Investigate. |
| AL-20 | **Posture drift**<br>new failed High or Critical CSPM control, overdue exception, coverage gap | Security Hub CSPM | P3 | Weekly digest. The owner fixes it by priority. |

## 8.3 Separate database users for public and admin

`CIS 3.3, 5.4, 6.8` `A.8.2, A.8.3` `CIS PostgreSQL` `WA SEC03`

**Short answer: yes, and go one step further, with one login per service**

Every service connects today as `alertingdb`, which is `rds_superuser` and owns the database (D47). An SQL injection in the public devices service would therefore control the whole database: admin users, guidance content and every location sample. Splitting public from admin is the minimum.

One login per service, each with only the privileges that service needs, costs little more. Secrets already sit under `/alerting/<env>/<component>/`, and the bootstrap Lambda already creates roles (D46). This extends CH-05 and addresses R10 and R17.

| ROLE | LOGIN | USED BY | PRIVILEGES | LIMITS |
|---|---|---|---|---|
| `alerting_owner` | No (NOLOGIN) | Nobody connects as it | Owns the schemas and tables. Migrations act through it with `SET ROLE`. | N/A |
| `alerting_migrate` | Yes | Flyway Job during deploys only | Member of the owner role. Can run DDL. | Connection limit 2. Secret readable only by the migrate pod role. |

| ROLE | LOGIN | USED BY | PRIVILEGES | LIMITS |
|---|---|---|---|---|
| `devices_app` | Yes | Public devices service | `INSERT` on position samples. Registration and check-in run through `SECURITY DEFINER` functions. No `SELECT` on device lists, accounts or any admin table. | Its own connection limit and `statement_timeout` |
| `geo_app` | Yes | Public geometry service | `SELECT` on area and geometry tables only | Its own connection limit |
| `admin_app` | Yes | Admin backend (admin plane) | DML on guidance and admin tables. `SELECT` on aggregated device views, not raw samples. No DDL. | A separate connection pool, so a public flood can't starve the admin plane |
| Named DBA roles | IAM token | Humans over the VPN (existing) | Read-only by default. Elevation through break-glass. | Session timeout. pgaudit logs everything they do. |
| `rds_superuser` (master) | Break-glass only | Bootstrap Lambda, emergencies | Full | Alert on every login (AL-16) |

- **RDS Proxy:** give each database user its own Secrets Manager secret. That is how RDS Proxy is designed to work (RDS Proxy credentials). Each pod's Pod Identity role may read only its own secret (8.4).
- **Connection limits:** set them per role with `CONNECTION LIMIT` (PostgreSQL CREATE ROLE). Add per-role `statement_timeout` and `idle_in_transaction_session_timeout` with `ALTER ROLE … SET`.
- **Hardening defaults:** revoke `CREATE` on the `public` schema, set default privileges, and grant on views instead of base tables where you can. Row-level security on device rows is optional, as defense in depth.
- **Ordering constraint:** `ddl-auto: update` (C23) needs DDL rights at runtime. The runtime roles can become DML-only only after Flyway takes over schema changes (CH-05). Until then, at least split public from admin and remove superuser from both.
- **Who changes what:** the platform team does the bootstrap Lambda, secrets and Proxy auth entries. The app team changes only the datasource username or secret path for each service and runs tests. That is a configuration change, not a code change.

## 8.4 Separate Kubernetes service accounts for public and admin

`CIS 5.4, 6.8` `A.8.2, A.8.22` `CIS EKS §RBAC` `WA SEC03`

**Short answer: yes, with one service account per workload, in separate public and admin namespaces**

Pod Identity is already in the design. Make each service account map to its own IAM role. An association links one service account to one role, with no annotations in the cluster (EKS Pod Identity). Pod Identity also tags each session with the namespace and service account name, so policies can be keyed on them (Pod Identity ABAC).

| NAMESPACE | WORKLOAD | SERVICE ACCOUNT | AWS ACCESS (POD IDENTITY) | KUBERNETES API |
|---|---|---|---|---|
| `public` | nginx (React client, emergency page) | `web` | None (later: read-only on the tiles bucket, CH-10) | None |
| `public` | Public Spring gateway | `gateway-public` | None | None |
| `public` | devices | `devices` | Read `/alerting/<env>/devices/*`, plus decrypt with that environment's KMS key | None |
| `public` | geometry, OSRM | `geometry`, `osrm` | Its own DB secret (geometry). None for OSRM. | None |
| `admin` | Angular console | `console` | None | None |
| `admin` | Admin gateway | `gateway-admin` | None | None |
| `admin` | backend | `backend` | Its own DB secret. Photo bucket put and get once C17 is decided. | None |
| `jobs` | Flyway migration | `migrate` | Migration secret only | None |

- **Token mounting:** set `automountServiceAccountToken: false` on every application service account, because no app pod calls the Kubernetes API (Kubernetes). No application service account gets a Role or RoleBinding.
- **Kyverno rules** (Audit now, Enforce at 9.1.5): deny the `default` service account, require automount off, and deny cross-namespace service account references.
- **Trust policies:** limit each role's trust to its cluster, namespace and service account. Scope IAM to the exact secret ARN and KMS key. Turn on Access Analyzer unused-access findings.
- **Network separation:** NetworkPolicies deny all traffic between `public` and `admin`, in both directions. Only the gateways may receive traffic from their own Envoy. Security groups for pods can also limit which pods reach RDS Proxy. This is optional, but it adds a network-layer check behind the database roles.

- **Separate node group for admin:** optional for later. The four-node cap makes it expensive now, and namespaces with PSA `restricted` and NetworkPolicies already cover release one.

## 8.5 A separate hostname for admin `CIS 12.2, 12.8` `A.8.20, A.8.22` `WA SEC05`

> **Short answer: you already have something stronger than a subdomain, so keep it**
>
> Admin lives at `admin.alerting.internal`. That name exists only in private DNS, behind its own internal ALB, WAF and Envoy, and is reachable only over the VPN. `.internal` is reserved by ICANN for private use and will never be delegated in the public DNS (ICANNWiki).
>
> Moving admin to a public subdomain such as `admin.<public-domain>` would make it less secure, not more.

| OPTION | EXPOSURE | VERDICT |
|---|---|---|
| **Path on the public host** ( `/admin` ) | Shares the public WAF, origin, cookies and routes with the public site. One routing mistake exposes admin, which is exactly R01 today. | Reject |
| **Public subdomain** behind Imperva | The login page is reachable from the internet. A public TLS certificate publishes the name in Certificate Transparency logs, where anyone can list your subdomains (packet.guru). There is also a cookie-scope risk if anything sets cookies on the parent domain. | Avoid |
| **Private name, internal ALB, VPN only** (current design) | No public DNS record, no public certificate, no internet path. The attacker needs a VPN session with MFA first. | Keep |

- **Certificates:** the internal ALB needs a certificate from a private CA, such as AWS Private CA, because public CAs don't issue for `.internal`. That also keeps the name out of Certificate Transparency logs.
- **Real-domain naming, if wanted:** use a private hosted zone (split-horizon) and still a private CA. Never publish the record publicly.
- **Separate session state:** give admin cookies their own names, and set them host-only with `Secure`, `HttpOnly` and `SameSite=Strict`. The public site never sets cookies the admin host could read.
- **If Client VPN is replaced** (8.7): options A (the recommended one) and C need a public admin name and certificate, so the name becomes visible. Pick one that doesn't advertise its purpose, and rely on the identity layer, not on the name staying secret.
- **Separate the public domain too:** keep the public site on its own short official domain, separate from any corporate domain (CH-14), so a corporate DNS or certificate incident can't affect it.

## 8.6 Hardened container images `CIS 2.5, 4.1, 7.5` `A.8.8, A.8.9, A.8.19` `WA SEC06-BP02`

**Short answer: AWS doesn't publish its own hardened application images, but it points to Docker's**

The Well-Architected Security Pillar says to start from hardened images. For containers, it names Docker's hardened images in the ECR Public Gallery (WA SEC06-BP02). Docker Hardened Images have been free and open source under Apache 2.0 since December 2025 (Docker).

The current base, `openjdk:17.0.1-jdk-slim`, is deprecated and at a 2021 patch level, and it runs JDWP as root (C20, R03). Replace it.

| OPTION | WHAT IT IS | FIT FOR THIS JAVA 17 APP | VERDICT |
|---|---|---|---|
| **Docker Hardened Images**, Eclipse Temurin 17 JRE | Minimal, near-zero CVE images with SBOM and VEX. There are variants for CIS, FIPS and STIG, on amd64 and arm64 (DHI Temurin). | Strong fit. Amazon Inspector supports Docker's hardened images (Amazon Inspector), so the existing Inspector gate keeps working. | Recommended |
| **Amazon Corretto** official images | An AWS-built OpenJDK. The default `amazoncorretto:17` images now run on Amazon Linux 2023 (Corretto Docker). | Good fallback with AWS support behind it. It's larger, and ships a package manager and a shell. | Fallback |
| **AL2023 minimal** plus Corretto headless, built yourself | The AL2023 minimal image contains only what's needed to install other packages (AL2023 minimal). | Fully AWS-native, but you own the hardening and the rebuild cadence. | Possible |
| **Red Hat Hardened Images** | Supported in the Inspector scan API and ECR basic scanning (Red Hat). An open AWS request reports that ECR enhanced scanning fails on them (AWS containers roadmap). | Not yet, while enhanced scanning is the release gate. | Not now |
| **Bottlerocket** | A node operating system, not a container base image | Not relevant here. Nodes already run CIS L1 Ubuntu. | N/A |

### Image standard for every service

- **Multi-stage build:** compile and test with the JDK image, and run on a JRE-only hardened image. Tests are no longer skipped (C20).
- **Runtime settings:** non-root numeric UID, `readOnlyRootFilesystem`, all capabilities dropped, no shell or package manager in the runtime image where the variant allows it.
- **No debug agent:** remove `-agentlib:jdwp` from every image. Kyverno and the NetworkPolicy keep denying port 8787 as a backstop (CH-06).

- **Pinning and mirroring:** pin the base image by digest, and mirror it into ECR with a pull-through cache rule (ECR pull-through cache). Nodes then pull only from ECR, and the Kyverno registry allow-list stays ECR-only.
- **Rebuild cadence:** rebuild weekly and whenever the base image publishes a fix. Patch Critical CVEs within 7 days, and within 48 hours when a public exploit exists (AL-14). SBOM, provenance, cosign and immutable tags stay as they are.

## 8.7 Admin access without Client VPN: three lower-cost options

`CIS 6.3, 6.4, 6.5, 12.7` `A.5.15, A.8.5, A.8.20` `WA SEC02, SEC05`

> **Short answer: AWS Verified Access, with no servers to manage and 2FA always required**
>
> Client VPN charges per subnet association per hour, plus per connected admin per hour. In the AWS example, one association costs $0.10 an hour, and 10 connections for an hour cost $0.50, which is $0.05 each (AWS VPN pricing). Each connection also pays the standard public IPv4 charge. At up to 100 admins, the bill grows with every admin and every hour they stay connected, and it peaks during a real event.
>
> The three options below replace the VPN with identity-based access. The constraints are: no extra servers to run, budget first, and well secured. On that basis, **Option A, AWS Verified Access**, is recommended. Every part of it is AWS-managed, and it costs about $489 a month against about $1,030 for Client VPN.
>
> 2FA is never optional. In every option it is enforced at the identity provider, and super admins and governing-organization admins must use phishing-resistant MFA (security keys or passkeys). The application's own login and RBAC sit behind the access layer, not instead of it (R01).

**What has to be covered**

- **Browser access for all three admin groups** (location, governing organization, super admins) to the Angular console and the admin gateway, which sit behind the internal admin ALB.
- **Engineering access for super admins only:** the private EKS API endpoint, Argo CD, and the DBA path to RDS Proxy. A private EKS endpoint can only be reached from inside the VPC or a connected network (Amazon EKS).
- **No new servers.** Nothing in the chosen design is an instance, a connector or a pod the team has to patch, monitor or rebuild.

### Comparison of options, including the considerations

| FACTOR | TODAY: CLIENT VPN + MFA | A: AWS VERIFIED ACCESS (RECOMMENDED) | B: CLOUDFLARE ZERO TRUST | C: ALB SIGN-IN WITH MFA |
|---|---|---|---|---|
| **Console access** | VPN tunnel to the internal ALB | Clientless browser access. Verified Access checks every request against the identity and device policy, then forwards it to the existing internal admin ALB. | Clientless browser access through Cloudflare Access, to a tunnel that runs outbound-only from inside the VPC (Cloudflare Tunnel) | The admin ALB becomes internet-facing. `authenticate-cognito` or `authenticate-oidc` signs users in before any request reaches the console (ALB authentication). |
| **Engineering access** | Same VPN | Connectivity Client to non-HTTP endpoints: one network CIDR endpoint for the EKS API on 443 (CIDR endpoints), and one RDS endpoint for RDS Proxy (RDS endpoints). Argo CD through `kubectl port-forward` over the EKS API, so it needs no endpoint of its own. | Cloudflare One client with private-network routes (Cloudflare private networks) | Needs a separate path: a jump node with Session Manager (a server), or CloudShell VPC environments |
| **How 2FA is enforced** | IdP MFA at VPN sign-in | At the trust provider. Either IAM Identity Center with MFA on every sign-in (no extra charge, AWS), or Entra ID through OIDC if Entra ID P1 is already licensed. A Cedar policy also checks group membership. | Entra-reported MFA, or Cloudflare's own independent second factor (Cloudflare MFA) | Cognito MFA set to required (Cognito MFA), or Entra with P1 |
| **Servers you manage** | None | **None.** Endpoints, policies and the client are AWS-managed. | A tunnel connector (`cloudflared`), run as two replicas on pods or instances, which you patch and monitor | None for the console. Engineering access needs a jump node unless CloudShell covers it. |
| **Software on admin devices** | VPN client on every admin device | None for the console. Super admins need the Connectivity Client, which runs on Windows and macOS only, not Linux (Connectivity Client). | None for the console. Cloudflare One client for super admins. | None |
| **What faces the internet** | The VPN endpoint | The AWS-managed Verified Access endpoint, with AWS WAF associated (WAF integration). The admin ALB stays internal. | The Cloudflare edge. The origin has no inbound path at all. | The admin ALB and its sign-in page |
| **Device posture** | None | Optional device trust providers, evaluated on every request (trust providers) | Built in, through the Cloudflare One client | Only through Entra P1 compliant-device rules |
| **Vendors and residency** | AWS only | AWS only. Logs stay in the log archive (B6 unchanged). | Adds Cloudflare as a processor of admin traffic and logs. Needs a B6 decision and a DPA. Needs a separate admin domain, because published hostnames need a zone on Cloudflare (Cloudflare routing). | AWS only |

| FACTOR | TODAY: CLIENT VPN + MFA | A: AWS VERIFIED ACCESS (RECOMMENDED) | B: CLOUDFLARE ZERO TRUST | C: ALB SIGN-IN WITH MFA |
|---|---|---|---|---|
| **What the cost scales with** | Connected admin-hours, which are highest during an event | The number of apps and endpoints, not the number of users. Up to 100 TCP connections per endpoint-hour are free (Verified Access pricing). | Users above 50 (Cloudflare pricing) | Almost nothing |
| **Indicative monthly cost at 100 admins** | ~$1,030, plus IPv4 per connection | **~$489:** console app ~$197, plus two TCP endpoints ~$292. About $197 if engineering access uses CloudShell only. | $350–$700, depending on whether the first 50 users stay free | ~$0, plus a jump node if CloudShell isn't enough |
| **Main limitations** | Cost rises with use. Network-level access once connected. | The console needs a public name and a public certificate (Verified Access endpoints), so the name appears in CT logs. The client has no Linux build. AWS doesn't test every OIDC provider, so validate in dev (user trust). | A second edge vendor beside Imperva, plus a connector to run | The sign-in page is internet-reachable. CloudShell sessions end after 20–30 minutes idle, and VPC environments keep no files (CloudShell limits). |
| **Verdict** | Replace | Recommended No servers, AWS-only, flat cost | Only if the team stays at 50 or fewer and Cloudflare is accepted | Cheapest but the most exposed, and engineering access is weaker |

Cost basis: us-east-1 list prices and 730 hours a month. Client VPN assumes two subnet associations (two AZs), with each admin connected 8 hours a day for 22 working days. Verified Access counts the console at $0.27 per app-hour and two non-HTTP endpoints at $0.20 per endpoint-hour, with negligible data at $0.02 per GB. Confirm list prices for the deployment region, and confirm availability in the console. A third-party list shows Verified Access in the deployment region (AWS Fundamentals). Estimates exclude tax and data transfer.

### Recommended for this programme: AWS Verified Access, with no servers to manage

- **Console, for all admins:** one HTTP Verified Access endpoint in front of the existing internal admin ALB. Associate the AWS WAF web ACL with the Verified Access instance.
- **Engineering access, for super admins:** two TCP endpoints through the Connectivity Client. One is a network CIDR endpoint for the EKS API on 443; the EKS API name resolves through public DNS to private VPC addresses, so `kubectl` works unchanged (Amazon EKS). The other is an RDS endpoint for RDS Proxy. Argo CD is reached through `kubectl port-forward`.
- **Break-glass and Linux users:** CloudShell VPC environments. CloudShell has no additional charge (CloudShell pricing), runs inside a chosen VPC subnet (VPC environments), and needs no server. Confirm that VPC environments are offered in the deployment region.
- **Identity:** IAM Identity Center as the trust provider, with MFA. It costs nothing extra and also covers AWS console access. Validate in dev that the chosen trust provider works for both the HTTP and the TCP endpoints. Use Entra ID through OIDC instead only if the client already has Entra ID P1, which is included in Microsoft 365 E3, E5 and Business Premium (Microsoft Entra licensing). Standalone, P1 is $7.00 per user per month (Microsoft Entra pricing), which is up to $700 a month for 100 admins.
- **Cheaper variant, if needed:** drop the two TCP endpoints and use CloudShell for all engineering work, for about $197 a month. Super admins then lose local tools, and sessions

end after 20–30 minutes idle.

| ID | MANDATORY CONTROL FOR OPTION A | DETAIL |
|---|---|---|
| HC-01 | **MFA required, never optional** | IAM Identity Center requires MFA on every sign-in. Super admins and governing-organization admins must use a security key or passkey. Location admins may use an authenticator app as a fallback. SMS and email codes are off. If Entra ID P1 is used, a Conditional Access authentication strength enforces the same rules (authentication strengths). |
| HC-02 | **Admin inventory** | Admins are created only by the admin-inventory owner (B3b), with group membership set at creation. Disable an account after 45 days without sign-in. Review all accounts every quarter. |
| HC-03 | **Group-based Cedar policies** | The location and governing-organization groups get the console endpoint only. Super admins get the console plus the EKS and RDS Proxy endpoints. The DBA endpoint can be limited further to a named DBA group. Everything not permitted is denied (Verified Access policies). |
| HC-04 | **Country restriction** | Cedar policies can match the client IP ( `context.http_request.client_ip` for HTTP, and the TCP flow context for TCP) (default context). Add an AWS WAF geo match on the instance's web ACL, allowing only the service country. Travel abroad needs a time-boxed exception ticket, alerted under AL-12. |
| HC-05 | **AWS WAF on the instance** | Use the core rule set, known bad inputs, the anonymous IP list and the IP reputation list. They work here because there is no proxy in front (AWS IP reputation groups). Add a per-IP rate limit and an admin route allow-list. |
| HC-06 | **Device posture for super admins** | If the client runs a supported device-management tool, attach it as a device trust provider and require a managed, encrypted, patched device for the EKS and RDS endpoints. If not, record it as an accepted gap and review it at the yearly exercise. |
| HC-07 | **Short sessions** | Set the IAM Identity Center session duration to 8 hours, matching today's VPN. A user disabled at the identity provider loses access when the session ends, and the Connectivity Client is re-authorized continuously while connected (Connectivity Client). |
| HC-08 | **The application verifies the signed identity** | The admin gateway verifies the `x-amzn-ava-user-context` JWT that Verified Access signs (user claims passing). It checks the signature, issuer and expiry, maps groups to roles, and rejects requests without a valid token. App RBAC is still required (R01). |
| HC-09 | **Low-visibility name, separate domain** | Use a non-descriptive hostname on a domain separate from the public site, with a public ACM certificate. The name will appear in Certificate Transparency logs, so security comes from the controls above, not from secrecy (8.5). The internal ALB and its private name don't change. |
| HC-10 | **Least-privilege TCP endpoints** | The CIDR endpoint covers only the subnets holding the EKS control-plane interfaces, on port 443. The RDS endpoint targets RDS Proxy only, never the database instance. Security groups admit only the Verified Access endpoint. |

| ID | MANDATORY CONTROL FOR OPTION A | DETAIL |
|---|---|---|
| HC-11 | **Logging and alerts** | Send Verified Access logs, with trust context included, to the log archive. Re-point AL-17 at them, and add P1 alerts for changes to policies, trust providers or the web ACL, for any MFA reset or disable, and for any admin created outside the inventory process. |
| HC-12 | **A break-glass path with no servers** | If Verified Access or the identity provider fails during an event, the break-glass role (7.2) opens a CloudShell VPC environment. From inside the VPC it reaches the EKS API, RDS Proxy and the admin gateway API, so urgent guidance changes can still be made. Rehearse this in the yearly exercise. |

**Applies to every option**

- Remove the Client VPN endpoint only after the new path has run in dev for two weeks, with a written rollback.
- Keep the three admin groups as identity-provider groups, mapped to access policies.
- The application's own authentication and RBAC are still required. The access layer is an outer gate, not a substitute.

This is decision B3c, and change CH-15.

## 8.8 AWS account and organization security

`CIS 3.3, 4.1, 5.4, 6.8, 8.2` `A.5.15, A.8.2, A.8.9, A.8.15, A.8.22` `CIS AWS Foundations` `WA SEC01, SEC03`

**Short answer: it was only partly covered, and this section adds the full baseline**

Until now, the strategy gave account-level security three items: one work item in 7.1 listing four SCPs, the multi-account split in CH-02 and SC-02, and root protection in SC-03.

This section defines the rest:

- the organization structure
- every guardrail policy, by type: service control policies (SCPs), resource control policies (RCPs), declarative policies, and the AI opt-out, backup and tag policies
- the settings every account must have
- how to protect the management account, which the guardrails don't reach
- a safe rollout order

It addresses R08 (dev and prd share one account) and R20 (root or break-glass misuse).

### Organization structure

Keep the structure flat and purpose-based, following AWS's recommended OUs (AWS multi-account guidance). Build it with Terraform in a separate organization pipeline that needs two-person approval.

| OU / ACCOUNT | PURPOSE | KEY SETTINGS |
|---|---|---|
| **Management account** (root of the organization) | Organizations, consolidated billing and the IAM Identity Center instance. No workloads, ever. | Every security service is delegated to the security-tooling account. Protected separately (see below), because SCPs and RCPs don't apply to it. |
| **Security OU** › security-tooling | Delegated administrator for GuardDuty, Security Hub, Inspector, Config aggregation, IAM Access Analyzer and Macie | Only the security team and read-only auditors have access. Findings route from here (8.2). |
| **Security OU** › log-archive | Organization CloudTrail, Config history, VPC flow logs, WAF, Imperva and Verified Access logs | S3 Object Lock and a KMS key owned by this account. No human write access. Retention follows CH-03. |
| **Security OU** › backup | Cross-account copies of RDS and other backups | AWS Backup vault with Vault Lock in compliance mode (AWS Backup Vault Lock), so not even an administrator can delete copies early |
| **Workloads OU › Prod** › prd | The production platform | Strictest SCPs. Humans are read-only, and changes go through the pipeline. |
| **Workloads OU › NonProd** › dev | Development and testing | Same guardrails as prd, apart from the prd-only human-write deny. No production data. |
| **Suspended OU** | Accounts being closed or quarantined after an incident | A deny-all SCP |

### Guardrail policies

- **SCPs** limit what identities in member accounts can do. They don't affect the management account or service-linked roles (AWS SCPs).
- **RCPs** limit what can be done to resources, whoever the caller is. They cover S3, KMS, STS, Secrets Manager, SQS, CloudWatch Logs and ECR, among others, and also exclude the management account and service-linked roles (AWS RCPs).
- **Declarative policies** are enforced in the service's control plane, so the setting holds even when AWS adds new APIs (AWS declarative policies).

| ID | TYPE | GUARDRAIL | ATTACHED TO | DETAIL AND EXCEPTIONS |
|---|---|---|---|---|
| GP-01 | SCP | **Deny leaving the organization** | Root | Deny `organizations:LeaveOrganization`. No exceptions. |
| GP-02 | SCP | **Region deny** residency (B6) | Root | Deny every Region except the home Region (`us-east-1`), using `aws:RequestedRegion`. Global services such as IAM, Organizations, Route 53, CloudFront, ACM for CloudFront, Shield, Support and billing are exempted through `NotAction`, because their calls are made in us-east-1. Start from the AWS example (AWS SCP examples). Also disable every other opt-in Region (AWS Regions). |
| GP-03 | SCP | **Security services can't be disabled** | Root | Deny stopping or deleting CloudTrail, Config recorders and delivery channels, GuardDuty detectors, Security Hub, Inspector, Macie and Access Analyzer, and leaving their delegated administrator. Exempt only the security automation role. Alerted under AL-05. |
| GP-04 | SCP | **No IAM users or long-lived keys** | Root | Deny `iam:CreateUser`, `CreateAccessKey` and `CreateLoginProfile`. People use Identity Center and pipelines use OIDC roles. Exempt only the documented break-glass process (7.2). |
| GP-05 | SCP | **Protect platform roles** | Root | Deny changes to `OrganizationAccountAccessRole`, the break-glass role, the Terraform deploy roles and the `AWSReservedSSO_*` roles, except by the organization pipeline role |
| GP-06 | SCP | **Deny root user actions in member accounts** | Root | Deny all actions where the principal is the account root. This complements centralized root access, which removes member root credentials entirely (AWS root user). |
| GP-07 | SCP | **Protect the log archive and its keys** | Security OU | Deny deleting log buckets and changing their bucket policy, lifecycle or Object Lock settings. Deny deleting security log groups, and disabling or scheduling deletion of security KMS keys. Exempt only the security role (AL-06). |
| GP-08 | SCP | **Encryption and public-access settings can't be weakened** | Root | Deny `ec2:DisableEbsEncryptionByDefault`, and deny changes to S3 account-level Block Public Access. Deny creating an RDS instance or cluster when `rds:StorageEncrypted` is false. |

| ID | TYPE | GUARDRAIL | ATTACHED TO | DETAIL AND EXCEPTIONS |
|---|---|---|---|---|
| GP-09 | SCP | **Network changes only through the pipeline** | Workloads OU | Deny creating or attaching internet gateways, VPC peering, transit gateway attachments, and changes to route tables and NACLs, except by the platform pipeline role. This stops a stolen human session from opening a new path out. |
| GP-10 | SCP | **Humans are read-only in prd** | Prod OU | Deny write actions to every `AWSReservedSSO_*` role except the Operator scaling actions and the break-glass permission set. All changes come through Terraform and Argo CD. This puts 7.2 into practice. |
| GP-11 | SCP | **Suspended OU: deny all** | Suspended OU | Deny `*` on `*`, for accounts being closed or quarantined |
| GP-12 | RCP | **Data perimeter: only our organization** | Root | Deny access to S3, KMS, Secrets Manager, SQS, STS and CloudWatch Logs when `aws:PrincipalOrgID` isn't ours and the caller isn't an AWS service. List any third-party integration explicitly, for example a vendor log-delivery role. Find them first with Access Analyzer external-access findings. |
| GP-13 | RCP | **TLS only** | Root | Deny S3, KMS, Secrets Manager and SQS requests where `aws:SecureTransport` is false |
| GP-14 | RCP | **Confused-deputy protection** | Root | Deny AWS service principals acting on our resources on behalf of another organization (`aws:SourceOrgID`). This stops a service being tricked into using our bucket or key for someone else. |
| GP-15 | Declarative | **Block public AMIs and snapshots** | Root | Image Block Public Access and Snapshot Block Public Access (declarative policy attributes) |
| GP-16 | Declarative | **VPC Block Public Access** | Root | Block in the security and dev accounts. In prd, exclude only the public ALB and NAT subnets, so no other subnet can ever get an internet path. |
| GP-17 | Declarative | **Instance metadata, serial console, allowed images** | Root | Require IMDSv2 with a hop limit of 1, so pods can't reach node credentials. Pod Identity doesn't need IMDS, but validate the add-ons. Disable serial console access. Allow images only from Amazon, the CIS image publisher and our own accounts. |
| GP-18 | AI opt-out | **Opt out of AI service content use** | Root | Opt out for all supported services. It applies in every Region, and AWS deletes historical content it doesn't need (AWS AI opt-out policies). This supports privacy by design (7.5). |

| ID | TYPE | GUARDRAIL | ATTACHED TO | DETAIL AND EXCEPTIONS |
|---|---|---|---|---|
| GP-19 | Backup | **Organization backup policy** | Workloads OU | Daily and weekly RDS backup plans, with a copy to the backup account vault, applied by tag (AWS backup policies) |
| GP-20 | Tag | **Required tags** | Root | Standardize `env`, `owner`, `data-class` and `component` (AWS tag policies). These feed the backup policy, cost reports and the Pod Identity ABAC conditions (8.4). |

### Baseline settings in every account

Apply these with the same Terraform module in every account, and check them with Security Hub CSPM.

| ID | SETTING | DETAIL |
|---|---|---|
| AB-01 | **Organization CloudTrail** | All accounts and Regions, management events, log file validation, and KMS encryption, delivered to log-archive (AWS organization trail). Add data events on the buckets that hold personal data or exports. |
| AB-02 | **AWS Config everywhere** | Record all resource types in the home Region, and global resources once. An organization aggregator in security-tooling (AWS Config aggregation). This unblocks the CIS standard (CH-08). |
| AB-03 | **GuardDuty for the whole organization** | Delegated administrator, with every account enrolled automatically (GuardDuty with Organizations). Protection plans: S3, EKS audit logs and runtime, RDS, and Malware Protection. |
| AB-04 | **Security Hub central configuration** | One configuration policy for every account and Region, with the CIS AWS Foundations Benchmark and AWS Foundational Security Best Practices standards (Security Hub central configuration) |
| AB-05 | **Inspector and IAM Access Analyzer** | Inspector for EC2, ECR and Lambda, enabled automatically for new accounts. An organization-wide external-access analyzer, plus an unused-access analyzer, which is billed per role analyzed (IAM Access Analyzer). |
| AB-06 | **S3 account-level Block Public Access** | All four settings on, in every account (S3 Block Public Access). Locked by GP-08. |
| AB-07 | **EBS encryption by default** | On, with a customer managed key, in the home Region (EBS encryption by default). Locked by GP-08. |
| AB-08 | **Alternate contacts** | Security, operations and billing contacts set centrally to monitored team mailboxes and an on-call phone, not to individuals (AWS alternate contacts). Security Hub checks this. |

| ID | SETTING | DETAIL |
|---|---|---|
| AB-09 | **No default VPCs** | Delete them in every Region of every account (CH-08) |
| AB-10 | **Cost guardrails as a security signal** | AWS Budgets per account, and Cost Anomaly Detection (Cost Anomaly Detection), routed as P2. A sudden compute spike is often the first sign of crypto-mining after a credential leak. |
| AB-11 | **Pipeline identity without keys** | GitHub Actions uses an IAM OIDC provider. Trust is scoped to repository, branch and environment, through the `sub` claim (IAM OIDC). Roles that the pipeline creates must carry a permission boundary (permission boundaries). |
| AB-12 | **Centralized root access** | Delete root credentials in every member account. New accounts are created with none. Privileged root tasks, such as unlocking a bucket policy that denies everyone, run from the management account (AWS root user). |

### Protecting the management account

SCPs and RCPs never apply to the management account (AWS SCPs). It must therefore be protected by process and detection (AWS management account best practices):

- No workloads, and no resources beyond Organizations, billing and Identity Center.
- Two named administrators at most, through Identity Center with security keys.
- The root user has two hardware MFA keys, kept in separate safes, with a sealed-envelope custodian process (SC-03).
- Any sign-in to the management account raises a P1 alert, extending AL-03.
- Every security service is delegated out to security-tooling, so day-to-day work never needs the management account.

### Safe rollout order

1. **Create the organization and accounts** (CH-02). Turn on the organization trail and log-archive first, so everything after this step is recorded.
2. **Delegate the security services** to security-tooling, and apply the account baseline (AB-01 to AB-12).
3. **Attach SCPs to NonProd first.** Test them in dev for a week with IAM policy simulation and Access Analyzer policy checks, then attach them to Prod.
4. **Inventory external access** with Access Analyzer before attaching the RCPs (GP-12 to GP-14), so legitimate integrations are listed as exceptions rather than broken.
5. **Attach the declarative policies** once the AMI and subnet exceptions are known.
6. **Centralize root access** and delete member root credentials last, after break-glass has been tested.

# What has to change in the current setup

These items change an accepted decision, a design or live state. Each change shows the decision it revises, who owns it, and whether the platform team can do it without touching `app/`.

| ID | CURRENT | CHANGE TO | WHY | OWNER | PRI |
|---|---|---|---|---|---|
| **CH-01** | Public nginx proxies the whole `/api`. The devices route carries the whole controller. | Exact-match HTTPRoutes for public methods and paths only. Imperva and AWS WAF rules deny everything else, including Swagger and actuator. | Contains R02 now, without editing `app/` | Platform team | **P0** |
| **CH-02** | D44: one account for dev and prd | AWS Organizations with prd, dev, log-archive, security-tooling and backup accounts. SCP guardrails. Move prd before go-live if possible, otherwise within 90 days. Full design in 8.8. | R08, residency SCP, cost tags (payer) | Platform team + client (B25) | **P1** |
| **CH-03** | D35: all logs 30 days, no archive | Security and audit logs: 1 year hot plus 6 years in Glacier, Object Lock. Operational logs: 30 to 90 days. Access logs: 1 year. | R13, CIS 8.10 (at least 90 days), A.8.15, legal holds | Platform team + client | **P0** |
| **CH-04** | D34: location samples kept permanently. C15: email per device. | Raw samples deleted 30 days after the event closes (proposed, for legal review). Aggregates by area and time kept for planning. Email removed. | R06, GDPR Art. 5, data minimization | Client + app team | **P0** |
| **CH-05** | D47: `alertingdb` is `rds_superuser` and owner. `ddl-auto: update`. | Owner, app and read-only roles created by the bootstrap Lambda. Migrations through Flyway as a Job. Runtime gets DML only. | R10, R17, CIS PostgreSQL | Platform team + app team | **P1** |
| **CH-06** | Dockerfiles: JDWP 8787, root, `openjdk:17.0.1`, tests skipped | Hardened multi-stage images. In the meantime, a Kyverno rule denies container ports 8787 and runAsUser 0, and a NetworkPolicy denies 8787. | R03 | App team, with platform-team interim controls | **P0** |
| **CH-07** | AWS WAF COUNT, Kyverno Audit, origin mTLS optional | BLOCK, Enforce and mandatory mTLS, each with a 7-day clean COUNT/Audit report as evidence | R09 | Platform team | **P0** |
| **CH-08** | CIS standard INCOMPLETE, default VPC present | Re-enable CIS v5.0.0 after Config, delete default VPCs in all Regions, and record v7.1.0 deltas | R19 | Platform team | **P0** |
| **CH-09** | Plain HTTP between services (C9) | Short term: tighter NetworkPolicies per port. Medium term: mTLS between services through Envoy or a mesh (for example Istio ambient) with SPIFFE identities. | R12 | Platform team | **P1** |

| ID | CURRENT | CHANGE TO | WHY | OWNER | PRI |
|---|---|---|---|---|---|
| **CH-10** | Public OpenStreetMap tiles (C13) | Self-host vector tiles for the service area, served from S3 through the edge | R15, privacy, surge | Platform team + app team | P2 |
| **CH-11** | Manual NOC scaling with no verification | A pre-approved "event mode" scale profile triggered from a signed runbook, with caller verification and two-person scale-down | R05, R14 | Platform team + CPA | P1 |
| **CH-12** | Emergency page served by nginx in the cluster | Also publish a signed static emergency page to S3 and cache it at Imperva as the origin-failover target | R05, principle 2 | Platform team | P0 |
| **CH-13** | No egress control described | VPC endpoints plus Network Firewall with an FQDN allow-list | Data exfiltration, C2 | Platform team | P1 |
| **CH-14** | Public domain trust not defined | One short official domain, DNSSEC, CAA, HSTS preload, tamper-evident QR plates, lookalike-domain monitoring | R04 | Client + Platform team | P1 |
| **CH-15** | Client VPN for all admin access (cost grows per admin-hour) | AWS Verified Access: an HTTP endpoint for the console in front of the internal admin ALB, and TCP endpoints for the EKS API and RDS Proxy. IAM Identity Center with mandatory MFA, AWS WAF on the instance, 8-hour sessions, and CloudShell VPC environments for break-glass. No new servers. Remove the VPN after two weeks of parallel running. | R01, cost, 8.7 | Platform team + client (B3c) | P1 |

10 · CONTROL MATRIX

# 35 strategic controls mapped to all four frameworks

This is the basis for the Statement of Applicability. Filter by Well-Architected area, status or priority, or type a framework reference such as `A.8.15` or `CIS 16`. In the PDF, all rows are shown.

| ID | STRATEGIC CONTROL | WA AREA | CIS CONTROLS V8.1 | CIS BENCHMARK | ISO 27001 ANNEX A | STATUS | PRI |
|---|---|---|---|---|---|---|---|
| SC-01 | ISMS: scope, policy set, risk method, Statement of Applicability, internal audit, management review<br>Risks: R08 | Foundations | – | – | Cl. 4–10, A.5.1, A.5.2, A.5.35 | Gap | P1 |
| SC-02 | Multi-account landing zone: Organizations, prd / dev / log-archive / security / backup accounts, SCP guardrails<br>Risks: R08 | Foundations | CIS 3.12, 12.2 | CIS AWS Foundations | A.8.22, A.8.31, A.5.23 | Change | P1 |
| SC-03 | Root and break-glass protection: hardware MFA, no keys, centralized root access, usage alarms, post-use review<br>Risks: R20 | IAM | CIS 5.4, 6.5 | CIS AWS Foundations · IAM | A.8.2, A.8.5 | Designed | P0 |
| SC-04 | Single workforce IdP, phishing-resistant MFA for VPN, AWS, Argo CD and console; JML process; quarterly reviews<br>Risks: R01 R11 | IAM | CIS 5.3, 6.1-6.3, 6.5, 6.7 | CIS AWS Foundations · IAM | A.5.16, A.5.17, A.5.18, A.8.5 | Gap | P0 |
| SC-05 | Admin console OIDC authentication and RBAC by authority, area and screen; seed account removed; BCrypt only<br>Risks: R01 | Application security | CIS 4.7, 6.8, 16.1 | OWASP ASVS L2 | A.5.15, A.8.3, A.8.5, A.8.26 | Gap | P0 |
| SC-06 | Workload identity: Pod Identity per service account, GitHub OIDC with pinned sub and workflow ref, no long-lived keys<br>Risks: R16 | IAM | CIS 6.1, 6.7 | CIS EKS · IAM | A.8.2, A.8.5 | Live | P1 |
| SC-07 | Least-privilege database roles: owner / app / read-only; IAM auth for DBAs; force TLS<br>Risks: R10 | Data | CIS 3.3, 5.4, 6.8 | CIS PostgreSQL 17 | A.8.2, A.8.3 | Change | P1 |
| SC-08 | Centralized, immutable logging with tiered retention (≥ 1 year security); application audit trail<br>Risks: R13 R01 | Detection | CIS 8.2, 8.5, 8.9, 8.10, 8.11 | CIS AWS Foundations · Logging | A.8.15, A.8.17, A.5.28 | Change | P0 |
| SC-09 | Threat detection and alert routing: GuardDuty (all protections), Security Hub, 24/7 paging, runbooks<br>Risks: R05 R16 | Detection | CIS 8.11, 13.1, 13.3 | CIS AWS Foundations · Monitoring | A.8.16, A.5.25, A.6.8 | Live | P1 |
| SC-10 | Posture management: Security Hub FSBP + CIS v5.0.0, Config conformance packs, v7.1.0 deltas via custom rules<br>Risks: R19 | Detection | CIS 4.1 | CIS AWS Foundations 5.0.0 → 7.1.0 | A.8.9, A.5.36 | Live | P0 |

| ID | STRATEGIC CONTROL | WA AREA | CIS CONTROLS V8.1 | CIS BENCHMARK | ISO 27001 ANNEX A | STATUS | PRI |
|---|---|---|---|---|---|---|---|
| SC-11 | Edge protection: Imperva WAF, DDoS and bot management, mandatory origin mTLS, Imperva-only origin<br>Risks: R05 R07 R09 | Infrastructure | CIS 12.2, 13.10 | CIS NGINX (headers, TLS) | A.8.20, A.8.21 | Designed | P0 |
| SC-12 | AWS WAF in BLOCK on origin and admin ALBs: managed rule groups, rate-based rules, path deny lists<br>Risks: R09 R02 | Infrastructure | CIS 13.10 | CIS AWS Foundations · Networking | A.8.20 | Designed | P0 |
| SC-13 | Public route allow-list at Envoy and nginx: exact paths and methods; Swagger and actuator denied<br>Risks: R02 | Infrastructure | CIS 4.4, 4.8, 12.2 | CIS NGINX | A.8.20, A.8.27 | Change | P0 |
| SC-14 | Network segmentation and egress control: default-deny NetworkPolicies, SGs, VPC endpoints, FQDN egress allow-list, no default VPC<br>Risks: R12 R19 | Infrastructure | CIS 4.4, 12.2, 13.4 | CIS AWS Foundations · Networking; CIS EKS | A.8.20, A.8.22 | Designed | P1 |
| SC-15 | EKS hardening to CIS EKS 2.0.0: private endpoint, access entries, audit logs, Secrets envelope encryption, PSA restricted, Kyverno Enforce<br>Risks: R09 R16 | Infrastructure | CIS 4.1, 2.5 | CIS EKS 2.0.0 | A.8.9, A.8.19 | Designed | P0 |
| SC-16 | Node OS hardening: CIS Ubuntu L1 (+ selected L2), IMDSv2 hop 1, SSM only, monthly rebuild, AMI pinning<br>Risks: R16 | Infrastructure | CIS 4.1, 4.8, 7.3 | CIS Ubuntu Linux L1 | A.8.8, A.8.9 | Designed | P1 |
| SC-17 | Service-to-service authentication: mTLS with workload identities (Envoy or ambient mesh)<br>Risks: R12 | Infrastructure | CIS 3.10, 12.2 | CIS EKS · Network | A.8.20, A.8.24 | Gap | P1 |
| SC-18 | Data classification and minimization: retention per class, aggregation, remove device email, rotating device IDs<br>Risks: R06 R02 | Data | CIS 3.1, 3.2, 3.4, 3.7 | — | A.5.12, A.5.34, A.8.10, A.8.11 | Change | P0 |
| SC-19 | Encryption and key management: KMS CMKs per env, split key policies, rotation, TLS 1.2+ in transit everywhere<br>Risks: R10 | Data | CIS 3.10, 3.11 | CIS AWS Foundations · Storage | A.8.24 | Designed | P1 |
| SC-20 | Secrets management: Secrets Manager under /alerting/<env>/, CSI-mounted files, rotation, Terraform shells only<br>Risks: R10 | Data | CIS 3.11 | CIS EKS · Secrets | A.5.17, A.8.24 | Designed | P1 |
| SC-21 | Backup and recovery: AWS Backup, PITR, cross-account vault with Vault Lock in us-east-1, quarterly restore tests<br>Risks: R05 | Data | CIS 11.1–11.5 | CIS AWS Foundations · Storage | A.8.13, A.8.14, A.5.30 | Gap | P1 |
| SC-22 | Secure SDLC and Phase 12 remediation to OWASP ASVS 5.0 Level 2<br>Risks: R01 R02 | Application security | CIS 16.1, 16.2, 16.10 | OWASP ASVS L2 | A.8.25, A.8.26, A.8.28, A.8.29 | Gap | P0 |

| ID | STRATEGIC CONTROL | WA AREA | CIS CONTROLS V8.1 | CIS BENCHMARK | ISO 27001 ANNEX A | STATUS | PRI |
|---|---|---|---|---|---|---|---|
| SC-23 | Container image hardening: supported JRE base, non-root, no JDWP, minimal image, tests in CI<br>Risks: R03 | Application security | CIS 2.2, 4.1, 16.4 | CIS Docker | A.8.8, A.8.9 | Gap | P0 |
| SC-24 | Supply-chain integrity: SHA-pinned actions, SBOM, provenance, cosign verify in Kyverno, signed commits, CODEOWNERS<br>Risks: R16 | Application security | CIS 2.5, 16.4, 16.5 | CIS EKS · Images | A.8.4, A.8.30, A.8.32 | Live | P1 |
| SC-25 | Vulnerability management: Inspector, Trivy, ECR scanning, SLAs 7/30/90 days, weekly image rebuild<br>Risks: R03 R16 | Detection | CIS 7.1-7.7 | CIS EKS · Images | A.8.8 | Live | P1 |
| SC-26 | Public-flow abuse protection: device tokens, per-token and per-IP rate limits, check-in anomaly detection<br>Risks: R07 R05 | Application security | CIS 13.10, 16.1 | OWASP ASVS L2 | A.8.26, A.8.16 | Gap | P0 |
| SC-27 | Incident response program: plan, roles, 8 playbooks, forensics role, exercises<br>Risks: R04 R05 | Incident response | CIS 17.1-17.9 | — | A.5.24-A.5.28, A.6.8 | Gap | P1 |
| SC-28 | Independent penetration testing before go-live and at least yearly; retest of findings<br>Risks: R01 R02 | Incident response | CIS 18.1-18.5, 16.13 | — | A.8.29, A.5.35 | Gap | P0 |
| SC-29 | Supplier security: Imperva, IdP, app team, GitHub — contract clauses, DPAs, residency, evidence collection<br>Risks: R18 | Foundations | CIS 15.1-15.7 | — | A.5.19-A.5.23 | Gap | P1 |
| SC-30 | Security awareness and NOC procedures: role training, caller verification, two-person scale-down<br>Risks: R14 | Foundations | CIS 14.1-14.9 | — | A.6.3, A.5.37 | Gap | P1 |
| SC-31 | Public trust and anti-spoofing: one official domain, DNSSEC, CAA, HSTS preload, tamper-evident QR, lookalike monitoring<br>Risks: R04 | Infrastructure | CIS 12.2, 17.4 | CIS NGINX (HSTS) | A.5.7, A.8.20 | Gap | P1 |
| SC-32 | Asset and software inventory: Config resource inventory, mandatory tags, ECR and SBOM catalog<br>Risks: R19 | Foundations | CIS 1.1, 2.1 | CIS AWS Foundations | A.5.9 | Live | P2 |
| SC-33 | Surge availability: event-mode scale profile, static signed emergency page at the edge as origin failover<br>Risks: R05 | Infrastructure | CIS 11, 12.2 | — | A.5.29, A.5.30, A.8.6, A.8.14 | Designed | P0 |
| SC-34 | Self-hosted map tiles for the service area, served from S3 through the edge<br>Risks: R15 | Data | CIS 3.1, 15.4 | — | A.5.23, A.8.14 | Change | P2 |

| ID | STRATEGIC CONTROL | WA AREA | CIS CONTROLS V8.1 | CIS BENCHMARK | ISO 27001 ANNEX A | STATUS | PRI |
|---|---|---|---|---|---|---|---|
| SC-35 | Versioned schema migrations (Flyway or Liquibase), ddl-auto validate, migration role separate from runtime<br>Risks: R17 | Application security | CIS 16.1 | CIS PostgreSQL 17 | A.8.32, A.8.31 | Change | P1 |

# Four phases, gated by evidence rather than dates

Phase A can start this week and needs only the platform team. Phase B is the go-live gate. Phases C and D build toward ISO 27001 certification readiness and CIS IG3.

## 11.1 Phases

Phase A · next 2–3 weeks

### Contain

- CH-01 route allow-list and WAF deny rules
- CH-06 interim Kyverno and NetworkPolicy for JDWP and root
- CH-08 Security Hub CIS fix, default VPC
- Decide B3a, B25, B11
- Draft the ISMS policy and risk appetite

Phase B · before go-live

### Gate

- Phase 12 auth, RBAC and devices split (F5, C21)
- CH-07 WAF BLOCK, Kyverno Enforce, mTLS
- CH-03 log archive, CH-12 static failover
- Pen test and retest. DDoS and surge drill.
- CH-04 retention decision signed

Phase C · go-live + 90 days

### Segment

- CH-02 multi-account and SCPs
- CH-05 DB roles and migrations
- CH-09 service-to-service mTLS
- CH-13 egress allow-list
- IR playbooks exercised

Phase D · go-live + 12 months

### Certify

- SoA complete, internal audit, management review
- ISO 27001 Stage 1 and Stage 2 readiness
- CIS IG3 safeguards that apply
- Yearly pen test and red-team exercise
- CH-10 self-hosted tiles

## 11.2 Go-live security gates

- [ ] **G1 · Admin authentication and RBAC live**. OIDC against the IdP, MFA, seed account removed, every endpoint authorized (SC-05). Evidence: ASVS L2 V6 to V8 test report.
- [ ] **G2 · Public API surface reduced to an allow-list**. Device list, lookup and count are unreachable from the internet. Evidence: an external scan returns 404 or 403.
- [ ] **G3 · No debug agents, no root containers**. Kyverno Enforce report is clean.
- [ ] **G4 · AWS WAF in BLOCK (9.1.7)** on the origin and admin ALBs, after a 7-day clean COUNT period.

- [ ] **G5 · Kyverno Enforce (9.1.5)** including cosign verification for prd images.
- [ ] **G6 · Origin accepts only Imperva**, through mandatory mTLS plus the prefix list. Evidence: a direct connection to the origin is refused.
- [ ] **G7 · Rate limiting and device tokens** on all public write endpoints (SC-26).
- [ ] **G8 · Security logs immutable, kept at least 1 year** (CH-03). App audit trail of guidance changes in place.
- [ ] **G9 · Security Hub FSBP and CIS v5.0.0 at 95% or more**, with every failure an approved exception. GuardDuty runtime coverage at 100% (D40).
- [ ] **G10 · Independent pen test passed**. No open Critical or High findings after retest (B11).
- [ ] **G11 · Surge and DDoS drill passed**. 500,000 simulated users, failover to the emergency page proven (CH-12).
- [ ] **G12 · Data retention and residency signed off** (CH-04, B6). DPIA approved.

# How we will know it is working

Reported monthly to the Steering Committee, and as ISO 27001 clause 9.1 monitoring evidence. Most metrics come straight from Security Hub, Config, Inspector and GuardDuty.

| METRIC | TARGET | SOURCE | FRAMEWORK |
|---|---|---|---|
| Security Hub score, FSBP and CIS v5.0.0 | ≥ 95% | Security Hub | CIS 4, A.8.9 |
| Critical and High vulnerabilities past SLA | 0 | Inspector, Trivy | CIS 7, A.8.8 |
| Human identities with phishing-resistant MFA | 100% super admins, 100% MFA overall | IdP | CIS 6.5, A.8.5 |
| Access review completed on time | Quarterly, 100% | IdP and Identity Center | CIS 5, A.5.18 |
| prd images running signed and verified | 100% | Kyverno reports | CIS 2, A.8.32 |
| GuardDuty runtime coverage of nodes | 100% (D40 gate) | GuardDuty | CIS 10, A.8.7 |
| Mean time to acknowledge a High finding | < 30 min (event), < 4 h (normal) | Alarms topic | CIS 17, A.5.25 |
| Backup restore test success | Quarterly, 100% | AWS Backup | CIS 11, A.8.13 |
| Location data older than the retention limit | 0 rows | DB job report | CIS 3.4, A.8.10 |
| Emergency page availability during drills | ≥ 99.95% | Imperva and synthetics | A.5.30, A.8.14 |

# Open decisions, with a recommendation for each

These come from the brief's list of decisions the strategy needs. Each has a recommended option, so the Steering Committee can approve or reject rather than start from scratch.

B3a · Identity provider

### Recommend: client Entra ID

Federated to Client VPN (SAML), IAM Identity Center and the app (OIDC). Use Conditional Access and FIDO2 for super admins. Partner organizations join through B2B guests or their own federation. If the client cannot provide Entra, use IAM Identity Center as the IdP, but plan a manual joiner-mover-leaver process.

B3c · Admin access path

### Recommend: AWS Verified Access, with no servers

Replace Client VPN with Verified Access. Use one HTTP endpoint for the admin console in front of the internal admin ALB, and two TCP endpoints (EKS API and RDS Proxy) through the Connectivity Client for super admins. Use IAM Identity Center with mandatory MFA as the trust provider, and CloudShell VPC environments for break-glass. Cost is about $489 a month against about $1,030 for Client VPN at 100 admins, with nothing to patch or run. All twelve controls HC-01 to HC-12 are mandatory. See 8.7.

B3b · Admin inventory

### Recommend: named inventory per authority

Each authority names a sponsor who approves its users. There are three VPN groups mapped to app roles. Quarterly recertification. No shared accounts.

B6 · Residency

### Recommend: single-Region residency, enforced by SCP

Deny Regions other than us-east-1. Imperva logs and IdP data stay in the same jurisdiction, or move only with explicit approval. Without a second Region there is no cross-Region DR, so record that as an accepted risk, mitigated by Multi-AZ, a cross-account backup and edge failover.

B11 · Penetration test

### Recommend: independent firm in Phase 9

Scope: public site, admin console through the VPN, AWS configuration and the Kubernetes cluster. Schedule it after the Phase 12 fixes, then retest. Repeat yearly, and after major changes, as the DPIA's risk treatment plan requires.

B12 · NOC caller verification

### Recommend: ticket plus callback plus two-person rule

Scale-up can be done by one verified caller. Scale-down needs a second approver from a different organization. All requests are logged.

B22 · Imperva

### Recommend: tier with bot management and a DDoS SLA

Mandatory origin mTLS. Use only the Imperva client-IP header. Push logs to S3 in us-east-1, and confirm the push before go-live.

B25 · Prd account

### Recommend: yes, as part of an Organization

Create it before go-live if the timeline allows, because migrating prd later is harder. Also needed for cost-allocation tags (payer account).

C21 · App login timeline

### Recommend: hard go-live gate

The platform can contain the devices endpoints (CH-01) but cannot make up for having no admin login. G1 and G2 are not negotiable.

C17 · Photo path

### Recommend: presigned upload through the admin plane

Upload to S3 with a presigned PUT URL. Scan with GuardDuty Malware Protection for S3. Serve through the edge. The bucket is never public.

9.1.7 · 9.1.5

### Recommend: both before go-live

WAF BLOCK and Kyverno Enforce, each after a 7-day clean observation window, with the reports kept as evidence.

# Sources

Framework versions were checked on 2026-10-21. Internal references (D-, B-, C- and F- items) point to the project documents listed in the Security Brief.


1. CIS — The 18 CIS Critical Security Controls (v8.1). https://www.cisecurity.org/controls/cis-controls-list
2. Cisco — Framework Foundations: CIS Controls v8.1 Solution Brief (Implementation Groups). https://www.cisco.com/c/en/us/products/collateral/security/cis-controls-sb.html
3. CIS — CIS Benchmarks list. https://www.cisecurity.org/cis-benchmarks
4. CIS — Amazon Web Services Benchmarks (Foundations 7.1.0). https://www.cisecurity.org/benchmark/amazon_web_services
5. CIS — CIS Benchmarks April 2026 Update (AWS Foundations v7.0.0). https://www.cisecurity.org/insights/blog/cis-benchmarks-april-2026-update
6. CIS — CIS Benchmarks June 2026 Update (EKS v2.0.0). https://www.cisecurity.org/insights/blog/cis-benchmarks-june-2026-update
7. CIS — PostgreSQL Benchmarks. https://www.cisecurity.org/benchmark/postgresql
8. CIS — NGINX Benchmarks. https://www.cisecurity.org/benchmark/nginx
9. AWS — CIS AWS Foundations Benchmark in Security Hub CSPM. https://docs.aws.amazon.com/securityhub/latest/userguide/cis-aws-foundations-benchmark.html
10. AWS re:Post — Resolve a security score or compliance status in Security Hub. https://repost.aws/knowledge-center/security-hub-empty-score-status
11. AWS — Well-Architected Framework, Security pillar best practice areas. https://docs.aws.amazon.com/wellarchitected/latest/framework/a-security.html
12. AWS — Security Pillar: Security foundations and design principles. https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/security.html
13. ISO — ISO/IEC 27001:2022 and Amendment 1:2024. https://www.iso.org/standard/27001
14. Modulos — ISO/IEC 27001:2022 Annex A, 93 controls in four themes. https://docs.modulos.ai/frameworks/iso-27001/annex-a
15. OWASP — Application Security Verification Standard 5.0.0. https://github.com/owasp/asvs
16. GDPR — Article 5: Principles relating to processing of personal data. https://www.gdpr.org/regulation/article-5.html
17. EDPB (Irish DPC list) — Data Protection Impact Assessment requirements. https://www.edpb.europa.eu/system/files/decisions/ie_dpc_data-protection-impact-assessment.pdf
18. ISO/IEC 27701:2025 — Privacy information management systems (preview). https://cdn.standards.iteh.ai/samples/iso/iso-iec-27701-2025/999f0b4e27d84804be12758c821cc34e/iso-iec-27701-2025.pdf
19. AWS — AWS WAF baseline rule groups. https://docs.aws.amazon.com/waf/latest/developerguide/aws-managed-rule-groups-baseline.html
20. AWS — AWS WAF use-case specific rule groups. https://docs.aws.amazon.com/waf/latest/developerguide/aws-managed-rule-groups-use-case.html
21. AWS — AWS WAF IP reputation rule groups. https://docs.aws.amazon.com/waf/latest/developerguide/aws-managed-rule-groups-ip-rep.html
22. AWS — AWS Managed Rules changelog. https://docs.aws.amazon.com/waf/latest/developerguide/aws-managed-rule-groups-changelog.html

23. AWS — Using forwarded IP addresses in AWS WAF. https://docs.aws.amazon.com/waf/latest/developerguide/waf-rule-statement-forwarded-ip-address.html

24. AWS — Aggregating rate-based rules in AWS WAF. https://docs.aws.amazon.com/waf/latest/developerguide/waf-rule-statement-type-rate-based-aggregation-options.html

25. AWS — Setting the web ACL default action. https://docs.aws.amazon.com/waf/latest/developerguide/web-acl-default-action.html

26. Imperva — Create and manage policies (WAF Rules, ACL). https://docs-cybersec.thalesgroup.com/bundle/cloud-application-security/page/policies.htm

27. Imperva — Web Protection: WAF settings. https://docs-cybersec.thalesgroup.com/bundle/cloud-application-security/page/settings/waf-settings.htm

28. Imperva — Web Protection: security settings. https://docs-cybersec.thalesgroup.com/bundle/cloud-application-security/page/settings/security-settings.htm

29. Imperva — Rules. https://docs.imperva.com/bundle/cloud-application-security/page/rules/rules.htm

30. ipregistry — Travel eSIMs, home routing and IP geolocation. https://ipregistry.co/blog/travel-esim-ip-geolocation-home-routing

31. Microsoft — Conditional Access: block access by location. https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-block-by-location

32. AWS — Security Hub generally available with near real-time risk analytics (Dec 2025). https://aws.amazon.com/about-aws/whats-new/2025/12/security-hub-near-real-time-risk-analytics/

33. AWS — Automations in Security Hub. https://docs.aws.amazon.com/securityhub/latest/userguide/securityhub-v2-automations.html

34. AWS — GuardDuty attack sequence finding types. https://docs.aws.amazon.com/guardduty/latest/ug/guardduty-attack-sequence-finding-types.html

35. AWS — GuardDuty RDS Protection finding types. https://docs.aws.amazon.com/guardduty/latest/ug/findings-rds-protection.html

36. AWS — Security Hub controls for CloudWatch. https://docs.aws.amazon.com/securityhub/latest/userguide/cloudwatch-controls.html

37. AWS — Amazon Q Developer in chat applications. https://docs.aws.amazon.com/chatbot/latest/adminguide/what-is.html

38. AWS — Setting up database credentials for RDS Proxy. https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/rds-proxy-secrets-arns.html

39. PostgreSQL — CREATE ROLE (17). https://www.postgresql.org/docs/17/sql-createrole.html

40. AWS — Assign an IAM role to a Kubernetes service account (Pod Identity). https://docs.aws.amazon.com/eks/latest/userguide/pod-id-association.html

41. AWS — Grant Pods access to AWS resources based on tags. https://docs.aws.amazon.com/eks/latest/userguide/pod-id-abac.html

42. Kubernetes — Configure service accounts for Pods. https://kubernetes.io/docs/tasks/configure-pod-container/configure-service-account/

43. ICANNWiki — .internal. https://icannwiki.org/.internal

44. packet.guru — Certificate Transparency: anyone can list your subdomains. https://packet.guru/blog/certificate-transparency-subdomains

45. AWS — SEC06-BP02 Provision compute from hardened images. https://docs.aws.amazon.com/wellarchitected/latest/framework/sec_protect_compute_hardened_images.html

46. Docker — Docker makes hardened images free, open and transparent (Dec 2025). https://www.docker.com/press-release/docker-makes-hardened-images-free-open-and-transparent-for-everyone/

47. Docker Hub — Hardened Images: Eclipse Temurin. https://hub.docker.com/hardened-images/catalog/dhi/eclipse-temurin

48. AWS — Amazon Inspector supported operating systems and hardened images. https://docs.amazonaws.cn/en_us/inspector/latest/user/supported.html

49. Amazon Corretto — corretto-docker. https://github.com/corretto/corretto-docker

50. AWS — AL2023 minimal container image. https://docs.aws.amazon.com/linux/al2023/ug/minimal-container.html

51. Red Hat — Red Hat Hardened Images supported in AWS InspectorScan API and ECR basic scanning. https://www.redhat.com/en/blog/streamlining-container-security-red-hat-hardened-images-now-supported-aws-inspectorscan-api-and-ecr-basic-scanning

52. AWS containers roadmap — ECR enhanced scanning support for Red Hat Hardened Images (#2887). https://github.com/aws/containers-roadmap/issues/2887

53. AWS — ECR pull through cache: pulling an image. https://docs.aws.amazon.com/AmazonECR/latest/userguide/pull-through-cache-working-pulling.md

54. AWS — AWS VPN pricing (Client VPN). https://aws.amazon.com/vpn/pricing/

55. AWS — AWS Verified Access pricing. https://aws.amazon.com/verified-access/pricing/

56. AWS — Verified Access load balancer endpoints. https://docs.aws.amazon.com/verified-access/latest/ug/create-load-balancer-endpoint.html

57. AWS — Verified Access user-identity trust providers. https://docs.aws.amazon.com/verified-access/latest/ug/user-trust.html

58. AWS — Authenticate users using an Application Load Balancer. https://docs.aws.amazon.com/elasticloadbalancing/latest/application/listener-authenticate-users.html

59. AWS — Start a Session Manager session (port forwarding). https://docs.aws.amazon.com/systems-manager/latest/userguide/session-manager-working-with-sessions-start.html

60. AWS — Amazon EKS cluster API endpoint access. https://docs.aws.amazon.com/eks/latest/userguide/cluster-endpoint.html

61. Cloudflare — Cloudflare Tunnel. https://developers.cloudflare.com/cloudflare-one/networks/connectors/cloudflare-tunnel/

62. Cloudflare — Connect private networks. https://developers.cloudflare.com/cloudflare-one/networks/connectors/cloudflare-tunnel/private-net/

63. Cloudflare — Tunnel routing and published applications. https://developers.cloudflare.com/tunnel/concepts/routing/

64. Cloudflare — Enforce MFA in Access. https://developers.cloudflare.com/cloudflare-one/access-controls/policies/mfa-requirements/

65. Cloudflare — SASE / Zero Trust pricing. https://www.cloudflare.com/plans/sase-zero-trust.md

66. Microsoft — Microsoft Entra licensing. https://learn.microsoft.com/en-us/entra/fundamentals/licensing

67. Microsoft — Microsoft Entra plans and pricing. https://www.microsoft.com/en-us/security/business/microsoft-entra-pricing

68. Microsoft — Conditional Access authentication strengths. https://learn.microsoft.com/en-us/Entra/identity/authentication/concept-authentication-strengths

69. AWS — Amazon Cognito pricing. https://aws.amazon.com/cognito/pricing/

70. AWS — Adding MFA to a Cognito user pool. https://docs.aws.amazon.com/cognito/latest/developerguide/user-pool-settings-mfa.html

71. AWS — IAM Identity Center FAQs (pricing). https://aws.amazon.com/iam/identity-center/faqs/

72. AWS — Integrate Verified Access with AWS WAF. https://docs.aws.amazon.com/verified-access/latest/ug/waf-integration.html

73. AWS — Verified Access user claims passing and signature verification. https://docs.aws.amazon.com/verified-access/latest/ug/user-claims-passing.html

74. AWS — Verified Access default context for trust data. https://docs.aws.amazon.com/verified-access/latest/ug/trust-data-default-context.html

75. AWS — Verified Access example policies. https://docs.aws.amazon.com/verified-access/latest/ug/trust-data-iam-add-pol.html

76. AWS — Verified Access trust providers. https://docs.aws.amazon.com/verified-access/latest/ug/trust-providers.html

77. AWS — Verified Access network CIDR endpoints. https://docs.aws.amazon.com/verified-access/latest/ug/create-network-cidr-endpoint.html

78. AWS — Verified Access RDS endpoints. https://docs.aws.amazon.com/verified-access/latest/ug/create-rds-endpoint.html

79. AWS — Connectivity Client for Verified Access. https://docs.aws.amazon.com/verified-access/latest/ug/connectivity-client.html

80. AWS Fundamentals — AWS Verified Access region availability. https://awsfundamentals.com/regions/service/aws-verified-access

81. AWS — AWS CloudShell pricing. https://aws.amazon.com/cloudshell/pricing/

82. AWS — Creating a CloudShell VPC environment. https://docs.aws.amazon.com/cloudshell/latest/userguide/creating-vpc-environment.html

83. AWS — CloudShell limits and restrictions. https://docs.aws.amazon.com/cloudshell/latest/userguide/limits.html

84. AWS — Organizing your AWS environment: recommended OUs and accounts. https://docs.aws.amazon.com/whitepapers/latest/organizing-your-aws-environment/recommended-ous-and-accounts.html

85. AWS — Service control policies (SCPs). https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps.html

86. AWS — SCP examples (including Region deny). https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps_examples_general.html

87. AWS — Resource control policies (RCPs). https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_rcps.html

88. AWS — Declarative policies. https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_declarative.html

89. AWS — Declarative policy syntax and supported attributes. https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_declarative_syntax.html

90. AWS — AI services opt-out policies. https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_ai-opt-out.html

91. AWS — Backup policies. https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_backup.html

92. AWS — Tag policies. https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_tag-policies.html

93. AWS — AWS account root user and centralized root access. https://docs.aws.amazon.com/IAM/latest/UserGuide/id_root-user.html

94. AWS — Best practices for the management account. https://docs.aws.amazon.com/organizations/latest/userguide/orgs_best-practices_mgmt-acct.html

95. AWS — Enable or disable Regions in your account. https://docs.aws.amazon.com/accounts/latest/reference/manage-acct-regions.html

96. AWS — Update alternate contacts. https://docs.aws.amazon.com/accounts/latest/reference/manage-acct-update-contact-alternate.html

97. AWS — Creating a trail for an organization. https://docs.aws.amazon.com/awscloudtrail/latest/userguide/creating-trail-organization.html

98. AWS — AWS Config multi-account aggregation. https://docs.aws.amazon.com/config/latest/developerguide/aggregate-data.html

99. AWS — GuardDuty with AWS Organizations. https://docs.aws.amazon.com/guardduty/latest/ug/guardduty_organizations.html

00. AWS — Security Hub central configuration. https://docs.aws.amazon.com/securityhub/latest/userguide/central-configuration-intro.html

101. AWS — Getting started with IAM Access Analyzer. https://docs.aws.amazon.com/IAM/latest/UserGuide/access-analyzer-getting-started.html

02. AWS — S3 Block Public Access. https://docs.aws.amazon.com/AmazonS3/latest/userguide/access-control-block-public-access.html

03. AWS — EBS encryption by default. https://docs.aws.amazon.com/ebs/latest/userguide/encryption-by-default.html

04. AWS — Cost Anomaly Detection. https://docs.aws.amazon.com/cost-management/latest/userguide/manage-ad.html

05. AWS — IAM OIDC identity providers. https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_providers_create_oidc.html

06. AWS — Permissions boundaries for IAM entities. https://docs.aws.amazon.com/IAM/latest/UserGuide/access_policies_boundaries.html

107. AWS — AWS Backup Vault Lock. https://docs.aws.amazon.com/aws-backup/latest/devguide/vault-lock.html

---

Security strategy v1.0 · 2026-10-21 · Prepared from the Security Brief for the alerting system (AWS ACCOUNT_ID, us-east-1). Re-check against docs 02, 07, 11, 31 and 32 whenever they change. Public edition: identifiers are placeholders (ACCOUNT_ID, PRD_VPC_CIDR, DEV_VPC_CIDR, ORG_ID, REPO_ID), and organization names are generic (platform team, CPA, EMS).